

# Navigating Risk and Rewards

## Automated Security Playbook Collaboration Framework in Critical Infrastructure

Master Thesis







## **Navigating Risk and Rewards**

Automated Security Playbook Collaboration Framework in Critical Infrastructure

Master Thesis

February, 2026

By

Dodzi Kwasi Nuhoho

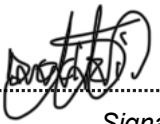
Copyright:      Reproduction of this publication in whole or in part must include the customary bibliographic citation, including author attribution, report title, etc.

Published by:    DTU, Department of Electrical and Photonics Engineering, Ørstedes Plads, Building 343, 2800 Kgs. Lyngby Denmark  
[www.electro.dtu.dk](http://www.electro.dtu.dk)

## Approval

This thesis has been prepared over six months at the Section for Communication Technologies, Department of Electrical and Photonics Engineering, at the Technical University of Denmark, DTU, in partial fulfilment for the degree Master of Science in Engineering (MSc Eng) in Communications Technologies and System Design.

Dodzi Kwasi Nuhoho - s240054

  
.....  
*Signature*

15 / 02 / 2026  
.....  
*Date*

## Abstract

The digital transformation of critical national infrastructure, particularly within the telecommunications sector, has intensified the security asymmetry between attackers and defenders. Mobile Network Operators (MNOs) face sophisticated threats from state-sponsored actors targeting specialized protocols such as SS7 and Diameter. Despite these risks, these operators often lack the comprehensive information sharing common in standard enterprise IT environments, complicating the establishment of a unified defense. This thesis investigates the transition from human-readable legacy security playbooks to machine-readable, vendor-agnostic formats using the Collaborative Automated Course of Action Operations (CACAO) version 2.0 specification.

Through a qualitative methodology involving expert interviews and a practical workshop at TDC NET, this research demonstrates that while automation and orchestration significantly reduce Mean Time to Detect (MTTD) and Mean Time to Respond (MTTR), external information sharing is frequently hindered by a lack of trust and reciprocity. To address these barriers, the study proposes a Decentralized Sharing Model utilizing the Malware Information Sharing Platform (MISP). This framework integrates functional anonymity via trade association intermediaries and a community-driven credibility loop involving peer feedback and quantitative ratings. The findings suggest that by decoupling process logic from proprietary tooling and fostering a verified, anonymous community, MNOs can achieve the collective resilience necessary to protect critical infrastructure against modern cyber threats.

## Acknowledgements

Special thank you to everyone who supported this thesis project.

I would like to express my profound gratitude to my external supervisor, **Michael Dreyer Kollemorten**, Security Analyst, TDC NET, for his continuous guidance. His assistance in establishing connections with other security analysts, as well as coordinating the workshop and interview sessions, provided essential industry insights. Furthermore, his efforts in clarifying core concepts and conducting thorough reviews were instrumental to the project's completion.

I also extend my thanks to my supervisor, **Sarah Renée Ruepp**, Associate Professor, DTU Electro, for her guidance, feedback, and support throughout the project.

Additionally, I am grateful to **Erik Gottschalk**, PhD student, DTU Electro, for his valuable insights, shared experience, and consistent support.

Finally, I appreciate the team at TDC NET, CDC, for their participation in the interviews, questionnaires, and workshops, with particular thanks to Manager **Lars Gottschalk** and the participating security analysts.

# Contents

|                                                                       |           |
|-----------------------------------------------------------------------|-----------|
| Preface . . . . .                                                     | ii        |
| Abstract . . . . .                                                    | iii       |
| Acknowledgements . . . . .                                            | iv        |
| <b>1 Introduction</b>                                                 | <b>1</b>  |
| <b>2 Playbooks in Information Security</b>                            | <b>4</b>  |
| 2.1 Role of Playbooks in Information Security . . . . .               | 4         |
| 2.2 Evolution of Playbooks . . . . .                                  | 6         |
| 2.3 Challenges faced by Playbooks . . . . .                           | 8         |
| 2.4 CACAO Specification . . . . .                                     | 8         |
| 2.5 Legacy to Machine Readable Playbooks . . . . .                    | 10        |
| <b>3 Operational Security</b>                                         | <b>11</b> |
| 3.1 Security Operations Centres (SOCs) . . . . .                      | 11        |
| 3.2 Operational Security Challenges . . . . .                         | 14        |
| <b>4 Automation and Orchestration</b>                                 | <b>16</b> |
| 4.1 Automation vs Orchestration . . . . .                             | 16        |
| 4.2 Artificial Intelligence in Automation and Orchestration . . . . . | 17        |
| 4.3 Interoperability and Integration Challenges . . . . .             | 17        |
| 4.4 Benefits and Risks . . . . .                                      | 17        |
| 4.5 Limitations of Current Automation Approaches . . . . .            | 18        |
| <b>5 Collaborative Defense and Information Sharing</b>                | <b>19</b> |
| 5.1 Threat Intelligence . . . . .                                     | 19        |
| 5.2 Information Sharing Platforms . . . . .                           | 22        |
| 5.3 Collaborative Requirements using Playbooks . . . . .              | 27        |
| <b>6 Research Methodology</b>                                         | <b>28</b> |
| 6.1 Phase I: Exploration . . . . .                                    | 28        |
| 6.2 Phase II: Investigations . . . . .                                | 28        |
| 6.3 Phase III: Validation . . . . .                                   | 28        |
| 6.4 Limitations and Consideration . . . . .                           | 29        |
| <b>7 Exploration and Validation</b>                                   | <b>30</b> |
| 7.1 Transformation of Playbooks . . . . .                             | 30        |
| 7.2 Qualitative Analysis . . . . .                                    | 33        |
| 7.3 Practical Session: Workshop . . . . .                             | 36        |
| <b>8 Discussion and Recommendation</b>                                | <b>39</b> |
| 8.1 Discussion . . . . .                                              | 39        |
| 8.2 Recommendation . . . . .                                          | 41        |
| <b>9 Conclusion and Future Work</b>                                   | <b>47</b> |
| <b>References</b>                                                     | <b>48</b> |

|          |                                         |           |
|----------|-----------------------------------------|-----------|
| <b>A</b> | <b>Appendix</b>                         | <b>53</b> |
| A.1      | Sample Phising CACAO Playbook . . . . . | 53        |
| A.2      | CMMI Maturity Model . . . . .           | 56        |
| A.3      | Workshop . . . . .                      | 57        |
| A.4      | Academic Polishing Agent . . . . .      | 69        |
| A.5      | Abbreviations . . . . .                 | 70        |



# 1 Introduction

As organizations and nations increasingly rely on digital systems to store data, deliver services, and support daily operations, information security has become a constant critical concern. Data breaches, service disruptions, and cyber incidents have tangible consequences, including financial losses, reputational damage, and risks to individual privacy. Despite significant investments in security technologies and policies, high-profile security failures continue to occur, raising important questions about why protecting modern information systems remains such a persistent challenge.

One of the most significant challenges in information security is the asymmetry between attackers and defenders. Attackers require only a single successful breach by exploiting a vulnerability, whereas defenders must continuously protect against all possible attack vectors across complex systems. This inherent asymmetry places defenders at a constant disadvantage, increasing the likelihood of security failures within organizations. As illustrated in Figure 1.1, threat actors leverage multiple independent vectors—such as malware, software vulnerabilities, phishing, and insider threats—often benefiting from the collective evolution of these methods. For an attacker to establish initial access, only one of these vectors is required. Conversely, defenders must simultaneously neutralize evolving threats; failing to secure even a single entry point results in a breach.

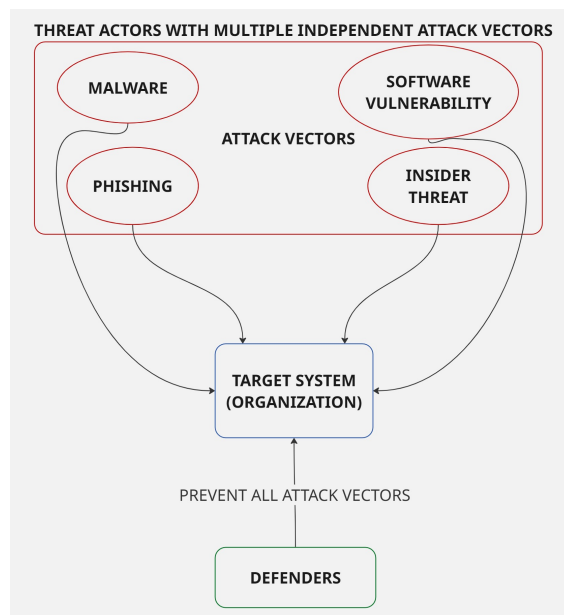


Figure 1.1: Asymmetry

To address this asymmetry, the ISO/IEC 27001 standard [1], among others, was developed to establish structured systems and controls for maintaining information security. However, the effectiveness of ISO/IEC 27001 depends on the consistent implementation, enforcement, and adherence to its prescribed policies, procedures, and regulations. When these controls are not properly followed, the advantage shifts further in favor of attackers, thereby widening the gap. The use of security playbooks enhances consistency in the application of these policies and operational processes, thereby strengthening overall defensive capability and maintaining information security.

Information security is further strengthened through established collaboration among defenders, particularly through the systematic sharing of threat intelligence. Organizations routinely share information on vulnerabilities, attack techniques, and indicators of compromise to enhance risk assessment activities and improve the effectiveness of security controls. However, current information-sharing practices primarily focus on the distribution of diagnostic data, which requires manual interpretation and leaves a critical gap between detection and execution. This reliance on human judgment allows divergent interpretations to introduce inconsistencies in incident handling, whereas a standardized, step-by-step approach to incident response within the security community would promote greater consistency and reliability.

This project examines how to enhance information security by leveraging collaborative, automated security playbooks among Mobile Network Operators (MNOs), which serve as critical infrastructure providers. An MNO is an organization that provides telecommunications services to its registered customers, including wireless voice and data. It also owns or controls the entire infrastructure, i.e., the radio network used to host and manage these services [2]. Given the essential role of mobile networks in supporting national and economic security, the coordinated automation of security responses enables more timely detection, information sharing, and mitigation of cyber threats. By examining existing collaborative practices and automated response mechanisms, this project assesses how these approaches enhance collective resilience within the telecommunications sector.

This study addresses the research questions outlined in Table 1.1. The initial focus is on transforming predominantly human-readable security playbooks into machine-readable formats to enable automation, alongside the evaluation of appropriate quality metrics, transformation accuracy, and behaviour under failure conditions. It also examines how playbooks can be shared and imported through existing community platforms, which are typically used for cyber threat intelligence rather than operational response. It assesses the factors that influence collaboration and the strengths and limitations of current open-source implementations. Finally, the research considers the practical deployment of automated playbooks within heterogeneous telecom environments, examining security practitioners' perceptions, scalability across complex infrastructures, and the optimal balance between human oversight and machine autonomy.

|            |                                                                                                                                                                                                                 |
|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>RQ1</b> | What should be the metrics for what is considered a good playbook by ISO/IEC 27001 standard? Should they be translated from human-readable to machine-readable formats, how accurately can they be transformed? |
| <b>RQ2</b> | How will the playbooks behave under failure scenarios?                                                                                                                                                          |
| <b>RQ3</b> | What factors influence the sharing and importing of playbooks from these open-sourced platforms?                                                                                                                |
| <b>RQ4</b> | How do Security Operation Center (SOC) analysts perceive automated playbooks running in the network?                                                                                                            |
| <b>RQ5</b> | How well will these automated playbooks scale across the infrastructure?                                                                                                                                        |
| <b>RQ6</b> | What will be considered an optimal balance between human oversight and machine autonomy when implementing this concept?                                                                                         |

Table 1.1: Research Questions

The theoretical framework and literature review for this project are organized into four sub-

sequent chapters. Chapter 2 (Playbooks in Information Security) defines security playbooks, examines their various formats, and discusses their role in maintaining information security. Chapter 3 (Operational Security) details the daily activities of security professionals and their utilization of specific tools and platforms. Chapter 4 (Automation and Orchestration) clarifies the concepts of automation and orchestration and demonstrates how their proper implementation helps defenders counter threat actors. Chapter 5 (Collaborative Defense and Information Sharing) addresses the current state of collaborative defense, the supporting technologies and platforms, and the significance of information sharing in maintaining collective security.

Chapter 6 (Research Methodology) outlines the research approach and acknowledges the limitations encountered during the study. Chapter 7 (Exploration and Validation) presents independent tests, workshops, and interviews conducted with security professionals at TDC NET to validate the risks and benefits of employing automated security playbooks within collaborative environments. This chapter contains findings that address a lot of the research questions in Table 1.1. Chapter 8 (Discussion and Recommendations) presents an analysis of the subject matter based on expert interviews and the existing literature, and offers practical recommendations relevant to the field. Finally, Chapter 9 (Conclusion and Future Work) summarizes the project's findings and identifies potential areas for further research given the current state of technology.

**Disclaimer:** An AI agent was developed on the Gemini[3] platform to refine the grammar and academic tone of this report. This process was conducted to ensure professional clarity without altering the original ideas, intent, or argumentative structure of the work. The specific prompt used to configure the agent is provided in Appendix A.4.

## 2 Playbooks in Information Security

Security playbooks have been defined in various ways by researchers and organizations, with related terms such as runbooks, response plans, and standard operating procedures often used interchangeably. This lack of consistency has prompted efforts to establish a standard definition. OASIS (Organization for the Advancement of Structured Information Standards), a non-profit organization, proposed a standardized definition in which “a playbook is a workflow for security orchestration containing a set of steps (security actions) to be performed based on a logical process and may be executed ad hoc, periodically, or triggered by an automated or manual event or observation” [4]. Similarly, Daniel Schlette et al. identified the need for a unified definition. They characterized a playbook as one that “describes a specific cybersecurity process or procedure based on a workflow with individual steps.” [5]

Despite differences in scope and emphasis, both definitions converge on the concept of a structured workflow composed of discrete steps. Building on this common foundation, this chapter examines the role of playbooks in information security, tracing their evolution from legacy, human-readable formats to modern machine-readable implementations. It further explores challenges related to interoperability and standardization and discusses how emerging specifications aim to address these limitations.

### 2.1 Role of Playbooks in Information Security

Information security is an umbrella term that encompasses an organization’s efforts to protect its information assets and resources. According to IBM, “Information security is the protection of important information against unauthorized access, disclosure, use, alteration, or disruption.” [6] Organizations enforce and maintain information security by establishing formal management systems. At its core, an Information Security Management System (ISMS) seeks to preserve the confidentiality, integrity, and availability of information assets through a continuous risk management process. The most widely recognized standard for implementing an ISMS is ISO/IEC 27001.

#### 2.1.1 ISO/IEC 27001 Standard

ISO/IEC 27001 is an international standard that specifies the requirements for establishing, implementing, maintaining, and continually improving an Information Security Management System (ISMS) [1]. The standard adopts a risk-based, process-oriented approach and does not prescribe specific technical measures; instead, it requires organizations to assess their unique risks and apply appropriate controls within a Plan–Do–Check–Act (PDCA) cycle of continuous improvement. The standard documentation is structured into clauses, which define the requirements for the ISMS, and annexes, which outline recommended security controls [1].

Security playbooks support the implementation of Clause 8 (Operation), which focuses on executing risk treatment plans derived from the outcomes of earlier risk assessment and planning activities in Clause 6 (Planning). As such, playbooks are primarily relevant to the operational layer of the Information Security Management System (ISMS), supporting security functions such as Security Operations Centres (SOCs), incident response teams, and security testing personnel. By translating high-level risk treatment decisions

into concrete workflows and response actions, security playbooks facilitate consistent and effective execution of operational controls.

The operational controls proposed by the standard include threat intelligence (Annex 5.7), which involves the collection and analysis of information regarding security threats, and information security incident management planning and preparation (Annex 5.24). The latter focuses on defining, establishing, and communicating incident management processes, roles, and responsibilities. Furthermore, monitoring activities (Annex 8.16) ensure that networks, systems, and applications are observed for anomalous behavior, with appropriate actions taken to evaluate potential security incidents[1]. Together, these elements bridge the gap between strategic ISMS requirements and day-to-day security operations.

While security playbooks primarily support the requirements of Clause 8 (Operation), they also contribute to fulfilling requirements across other clauses of the ISO/IEC 27001 standard. For example, playbooks that automate repetitive tasks promote consistency and repeatability, helping organizations maintain compliance during audits. For organizations where achieving ISO/IEC 27001 compliance may initially appear challenging and costly across the entire organization, complementary frameworks can be applied to assess and improve individual or collective processes. Capability Maturity Model Integration (CMMI) is such a framework, providing a structured approach to evaluating and enhancing process maturity.

### 2.1.2 Capability Maturity Model Integration

Capability Maturity Model Integration (CMMI) is a framework originally developed for software engineering that has since been adopted within information security to assess and improve organizational processes. The framework focuses on enhancing process capability and evaluating process maturity across an organization. In the context of information security, CMMI can be applied to processes and procedures for managing identified risks and responding to threat actors. As these processes mature, their outcomes become increasingly predictable, consistent, and repeatable.

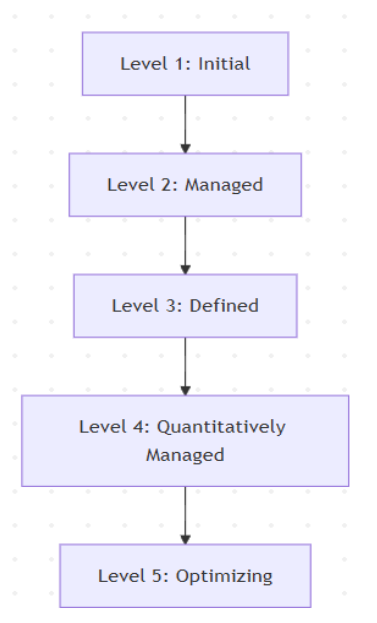


Figure 2.1: CMMI Levels [7]

CMMI defines five maturity levels: Initial, Managed, Defined, Quantitatively Managed, and Optimizing, as illustrated in Figure 2.1. At Level 1 (Initial), processes are typically ad hoc, chaotic, and heavily reliant on individual expertise. Security playbooks serve as a key artifact for addressing these limitations by formalizing and structuring security processes and procedures so that they can be consistently followed and reproduced by multiple personnel. The more effectively playbooks are defined, applied, and maintained, the higher the maturity level at which a process or organization can be appraised. At the highest maturity level (Optimizing), continuous improvement is driven by systematic feedback mechanisms, with enhancements that are not only incremental but also innovative.

By applying the CMMI framework to improve security processes and procedures, organizations can formalize these practices into security playbooks that support sustained information security and continuous improvement. In practice, the use of security playbooks is typically associated with achieving CMMI maturity Levels 2 (Managed) and 3 (Defined). Building on this foundation, a key objective of this study is to explore how security playbooks can be further refined and operationalized to support progression toward higher maturity levels, specifically Levels 4 (Quantitatively Managed) and 5 (Optimizing).

## 2.2 Evolution of Playbooks

Playbooks have existed in various formats over time, evolving alongside changes in both technology and the cyber threat landscape. Early security playbooks were typically documented as printed procedures stored in binders, outlining step-by-step responses to common incidents such as phishing attacks. As documentation practices were digitized, these procedures were converted to electronic formats, including PDFs and presentation slides, in which response steps were commonly presented as numbered lists or bullet points. While more accessible, these documents were often high-level and generalized, limiting their operational precision.

Subsequently, many organizations adopted wiki-based platforms to document incident response procedures. These platforms enabled security teams to centralize incident-related information and embed hyperlinks to relevant tools, documentation, and external resources. As cyberattacks became more frequent and complex, visual representations such as flowcharts gained prominence, enabling analysts to quickly understand detection and response processes. Business Process Model and Notation (BPMN) [8] diagrams, in particular, were commonly used to depict or model business processes. By adopting these diagrams, security stakeholders could better visualize workflows, thereby improving situational awareness during time-critical incidents.

Over time, it became apparent that certain response steps were well-suited to automation. For example, actions such as blocking an IP address could be automated by extracting the relevant indicator of compromise and executing a script to update firewall rules accordingly. This led to the introduction of runbooks, which are often confused with playbooks but serve a distinct purpose. Runbooks are typically executable scripts, such as shell or Python programs, that automate specific tasks within an incident response process. While playbooks, whether represented as flowcharts or wiki-based documents, may reference which runbooks should be executed at particular stages, runbooks themselves represent only isolated actions. As a result, although machines can readily execute runbooks, they lack a holistic view of the overall incident response workflow, which remains encapsulated within the broader playbook.

To enable machines to maintain a holistic view of an entire playbook, it became necessary to express playbooks in semantic, machine-readable formats. Data representa-



tion formats such as JSON (JavaScript Object Notation) and YAML emerged as common choices, and even when graphical user interfaces (GUIs) were used to design playbooks, the underlying structure still relied on these formats to ensure machine readability. Many security tool vendors that introduced playbook functionality adopted such formats within their platforms; however, these implementations were often proprietary and tightly coupled to vendor-specific tools. As a result, although automation and machine readability were achieved, organizations became locked into specific vendor ecosystems. Consequently, playbooks created to respond to specific attack scenarios are typically shared only with and reused by organizations that employ the same tooling, significantly limiting interoperability and broader community benefit.

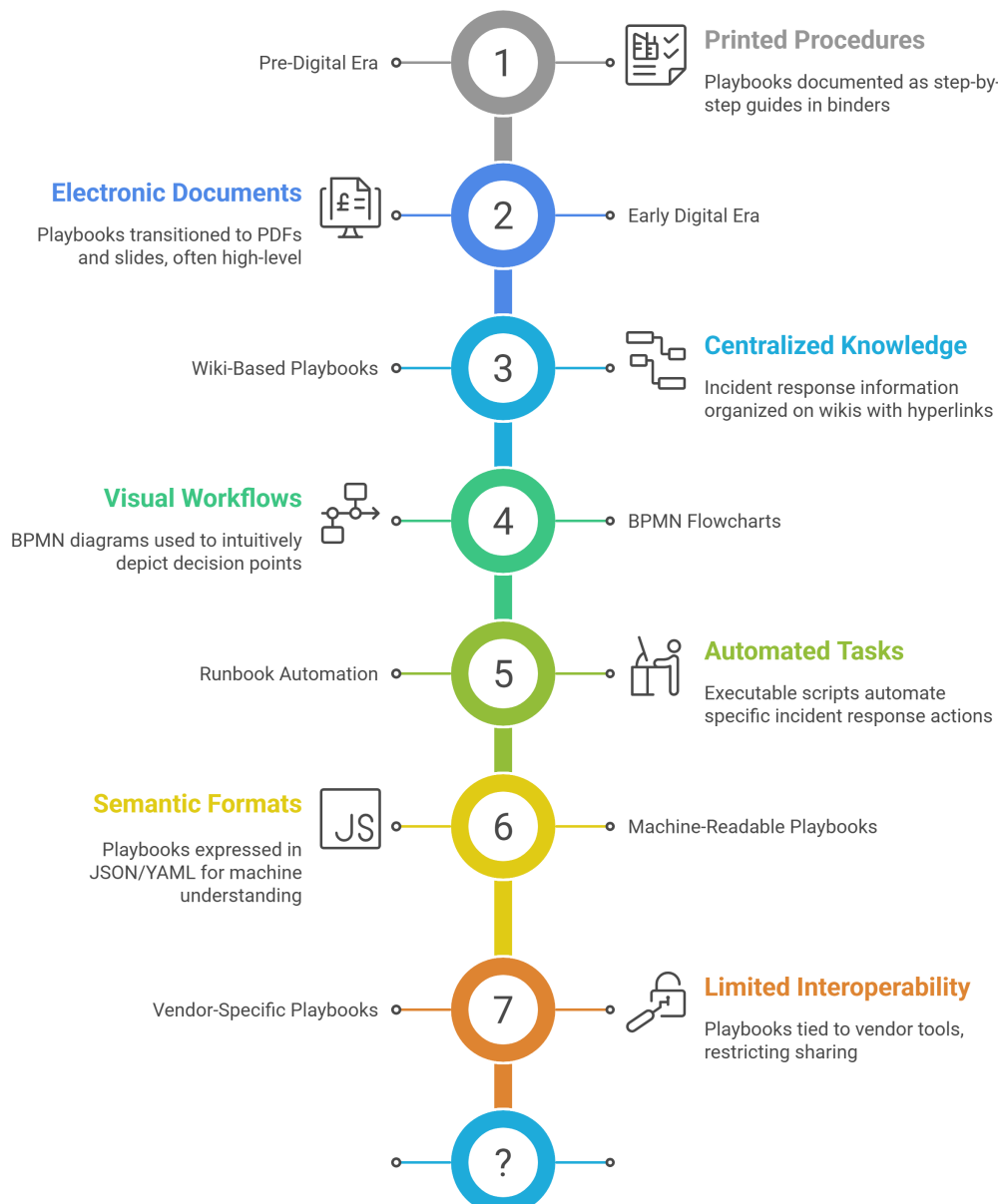


Figure 2.2: Evolution of Security Playbooks. [created with the assistance of Napkin AI]

Figure 2.2 illustrates the evolution of security playbooks across their various forms over time. The figure illustrates the concepts discussed in this section. Although some modern playbooks are now machine-readable, they are often implemented in vendor-specific

formats. This means that organizations must repeatedly reinterpret shared threat intelligence and reimplement response logic to align with their internal toolsets, or rely on subsets of the security community that use similar technologies. Addressing this challenge is central to this project and is represented as a question mark in Figure 2.2, as open, standardized, machine-readable playbook formats are essential for effective sharing, interoperability, and reuse across organizations.

## 2.3 Challenges faced by Playbooks

Based on an analysis of over 1,200 security playbooks, Schlette et al. [5] observed that the effective use of playbooks within organizations is influenced by a range of contextual factors that are often not fully considered by security tool vendors when creating community playbooks, even in legacy, human-readable formats. For example, a playbook developed outside the European Union may not adequately account for the requirements of the General Data Protection Regulation (GDPR), particularly when its creators do not operate within the EU, even though it addresses a relevant and complex threat scenario.

As a result, organizations seeking to adopt such playbooks must invest additional effort to tailor them to their specific infrastructure, regulatory environment, and tooling. This adaptation process can require significant expertise, especially given the differing terminology, concepts, and implementations across security tools. Consequently, community playbooks are rarely usable “out of the box,” despite being widely shared.

Conversely, playbooks tailored to a specific organization cannot be shared in full without raising confidentiality and privacy concerns. When expert teams document response processes and wish to share them externally, the content must be generalized through a sanitization process to avoid exposing sensitive internal information, tools, or operational details that could be exploited by threat actors. However, this sanitization inherently removes organization-specific context, effectively reverting the playbook to a generic community artifact. This tension between contextual usefulness and shareability represents a persistent challenge for security playbooks, regardless of their format, and is examined further in a later chapter in this project.

## 2.4 CACAO Specification

The effort to create CACAO (Collaborative Automated Course of Action Operations) security playbooks began in 2019, when OASIS chartered the CACAO Security Playbooks Technical Committee. The committee brought together vendors, government agencies, and practitioners who were struggling with the same problem: incident response playbooks were mostly static documents or vendor-specific automations that could not be easily shared, reused, or executed across different tools. Over the next several years, the group defined a machine-readable, JSON-based standard for representing security playbooks, iterating through working drafts and public reviews. This work culminated in the approval of CACAO Security Playbooks Version 1.0 as an OASIS Standard in 2022, followed by incremental refinements, clarifications, and alignment work through 2023 and 2024 as adoption and real-world feedback increased.

### 2.4.1 Motivation for CACAO

OASIS’s motivation for driving this work was fundamentally about interoperability and operational speed. Organizations faced increasingly automated and fast-moving threats, yet defenders lacked a common standard for encoding, sharing, and executing response

logic across Security Orchestration, Automation, and Response (SOAR) platforms, Security Information and Event Management (SIEM) systems, and other security tools. By standardizing how playbooks describe triggers, decision logic, actions, and integrations, OASIS aimed to reduce vendor lock-in, improve collaboration between organizations, and allow proven response strategies to be shared and executed consistently at machine speed—closing the gap between human knowledge and automated cyber defense.

### 2.4.2 Key Components

The Cacao specification defines the schema and taxonomy for Collaborative Automated Course of Action Operations (CACAO) security playbooks. This specification describes how security playbooks can be created, documented, and shared in a structured and standardized manner across organizational boundaries and heterogeneous technological environments [4]. It defines several types of playbooks based on certain actions. For instance, when identifying an incident or conducting threat hunting, the specification recommends using a detection playbook. Consequently, the specification defines eight types of playbooks for different tasks.

1. Attack Playbook
2. Detection Playbook
3. Investigation Playbook
4. Engagement Playbook
5. Mitigation Playbook
6. Notification Playbook
7. Prevention Playbook
8. Remediation Playbook

Figure 2.3 illustrates the structure of a CACAO security playbook, which is composed of a set of well-defined objects. The metadata object provides essential descriptive information about the playbook, including identifiers, authorship, and versioning details. The workflow object defines the playbook's overall execution logic and encapsulates the individual steps that constitute the response process. Each step is associated with one or more command objects, which specify the concrete actions to be executed.

The command object is a central component of the CACAO model, as it enables interoperability with a range of existing security standards and tools. Commands can reference detection logic expressed as Sigma rules, response actions defined in OpenC2, or executable artifacts, such as scripts and Jupyter notebooks. This design allows CACAO playbooks to integrate heterogeneous detection and response mechanisms within a single, coherent workflow, while avoiding tight coupling to specific vendor implementations. Based on the defined commands, a playbook may reference agents, targets, or other playbooks, thereby enabling modularity and reuse. Agents and targets are defined by dedicated objects and represent the entities responsible for executing commands or receiving actions within the operational environment, such as SOAR and SIEM.

Authentication information is managed through a dictionary object, which provides the credentials required by agents and targets to authenticate against relevant systems and resources. CACAO also incorporates security-focused components to support controlled sharing and integrity assurance. Data markings define how a playbook may be distributed

and handled across platforms and organizational boundaries, commonly using the Traffic Light Protocol (TLP). TLP classifications such as TLP: CLEAR, TLP: GREEN, TLP: AMBER, and TLP: RED establish progressively restrictive sharing guidelines, ranging from unrestricted public dissemination to limited sharing within a trusted group. By applying these markings, CACAO playbooks ensure that sensitive operational details are shared appropriately. In addition, the digital signature object specifies how playbooks are signed to verify their authenticity and preserve their integrity throughout distribution and execution.

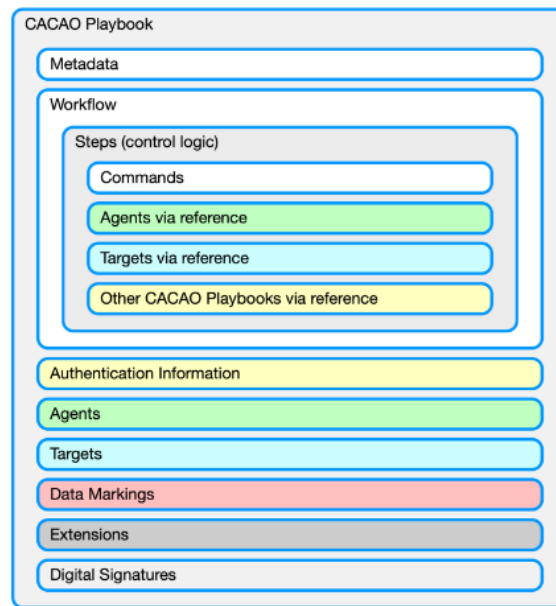


Figure 2.3: Cacao Playbook Structure [4]

## 2.5 Legacy to Machine Readable Playbooks

The majority of existing security playbooks are expressed in human-readable formats, such as PDF documents, as discussed earlier. However, effective automation requires playbooks to be parsed, validated, and executed by machines. The CACAO specification, being vendor-agnostic, enables legacy human-readable playbooks to be transformed into machine-readable representations, such as JSON. Nevertheless, manually converting each existing playbook and authoring new playbooks directly in machine-readable formats for future attack scenarios presents a significant practical challenge.

To address this issue, M. A. Gurabi et al. [9] proposed the use of large language models (LLMs) to accelerate the translation of legacy playbooks into the CACAO schema through prompt engineering. Their work specifically focused on mitigating LLM hallucinations during the transformation process by applying structured prompt engineering techniques to preserve both syntactic accuracy and semantic fidelity. This preservation is critical for automation, as translated playbooks are intended for execution in operational environments. Errors introduced during translation, particularly those that alter workflow logic or execution semantics, may lead to incorrect responses and could increase the risk of security incidents. The study mitigated these risks by incorporating a syntax validation mechanism and an iterative refinement process, significantly reducing translation errors [9].

### 3 Operational Security

Mobile network providers operate in a complex, rapidly evolving threat landscape, where large, distributed infrastructure generates a vast number of security events. As critical national infrastructure operators, Mobile Network Operators (MNOs) require the ability to detect, triage, and respond to potential threats in a structured and consistent manner. This operational reality aligns closely with the NIST Cybersecurity Framework (CSF) and the NIST Computer Security Incident Handling Guide (SP 800-61), which describe a cyclical process that moves from event detection through triage, incident response, and continuous improvement. The NIST CSF is a framework that provides guidelines for organizations to manage security risks. It is abstracted into six core functions as illustrated in Figure 3.1.



Figure 3.1: NIST CSF [10]

Table 3.1 provides a brief description of the aim of the functions proposed by the NIST Framework.

| Functions | Focus      | Definition                                                   |
|-----------|------------|--------------------------------------------------------------|
| Govern    | Strategy   | Establishing roles, policies, and risk management strategies |
| Identify  | Inventory  | Mapping assets (hardware, software, services, etc.)          |
| Protect   | Prevention | Implementing safeguards to prevent or mitigate risks.        |
| Detect    | Visibility | Monitoring, and analyzing events for suspicious activity.    |
| Respond   | Action     | Containing the impact of incidents.                          |
| Recover   | Resilience | Restoring systems back to normal operations.                 |

Table 3.1: NIST CSF Functions

#### 3.1 Security Operations Centres (SOCs)

A Security Operations Center (SOC), according to Fortinet, is a “command center for monitoring the information systems that an enterprise uses for its IT infrastructure.” [11]. This definition is limited to IT infrastructure, but it is important to note that it can also

be applied to Operational Technology (OT) infrastructure. The activities in a SOC primarily live in the Detect and Respond functions of the NIST Framework and, in some cases, the Recover function. A SOC encompasses the tools, roles, and responsibilities required to maintain an organization's security posture. To gain visibility across complex and distributed infrastructures, SOCs commonly deploy tools such as firewalls, intrusion detection systems (IDS), endpoint detection and response (EDR), network detection and response (NDR), ticketing systems, security information and event management (SIEM), and security orchestration, automation, and response (SOAR) platforms.

When integrated with threat intelligence platforms, these tools facilitate the collection, correlation, and analysis of security data, enabling a coordinated response to identified threats. While EDR and NDR are both utilized for threat identification and response, they operate at different levels: EDR monitors individual devices, such as laptops and servers, whereas NDR provides visibility into network traffic and communications. Security Information and Event Management (SIEM) further enhances this capability; according to NIST, it allows organizations to "gather security data from information system components and present that data as actionable information via a single interface" [12].

This integration provides a comprehensive view of activity across the entire infrastructure, facilitating more effective security analysis. Employing these tools to monitor various layers implements the principle of defense in depth, which utilizes multiple security controls and strategies to protect an asset. For example, if an attacker disables logging or circumvents detection on an endpoint, the NDR can still identify unusual network activity associated with that device, triggering an alert and further investigation.

### 3.1.1 Detection Processes

To ensure continuous monitoring of systems, security teams often follow established processes, and Figure 3.2 illustrates a typical SOC workflow for threat detection.

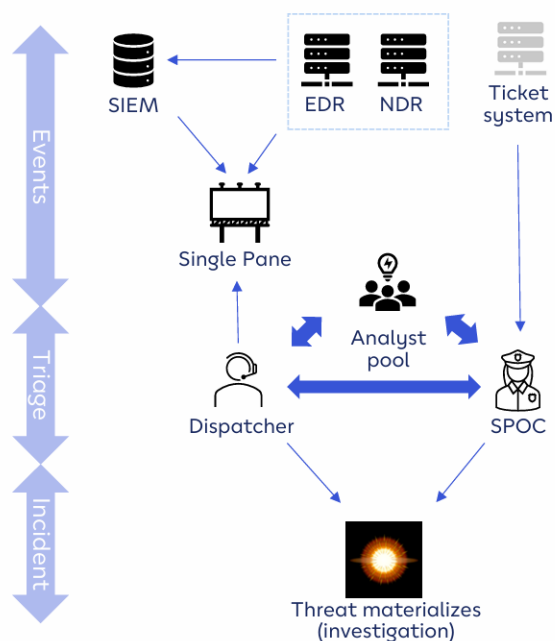


Figure 3.2: Detection Lifecycle

In this process, security events are generated by detection tools such as EDR and NDR, each producing alerts that require triage and correlation. These logs and alerts are aggregated by the SIEM and presented through a unified operational interface labeled as “single pane” in Figure 3.2, allowing analysts to review, prioritize, and investigate potential incidents more effectively. Users of the endpoints (laptops, etc.) can detect suspicious events and raise the alarm via the ticketing system, which aggregates user complaints. The SPOC (Single Point of Contact) escalates the issue to the appropriate role if the threat materializes, initiating the response process.

### 3.1.2 Incident Response Processes

During the response phase, the detected anomaly is investigated to determine the nature and severity of the threat. This process is typically led by an incident responder or security analyst, who decides whether to escalate the matter within the Security Operations Center (SOC) or to external stakeholders. As illustrated in Figure 3.3, this stage often involves the broader incident response team; consequently, clear communication is vital, as specific incidents may require the involvement of legal counsel or executive leadership. The iterative nature of this coordination is represented by the bidirectional arrow in Figure 3.3, which links the Security Incident Management Process with the escalation procedures.

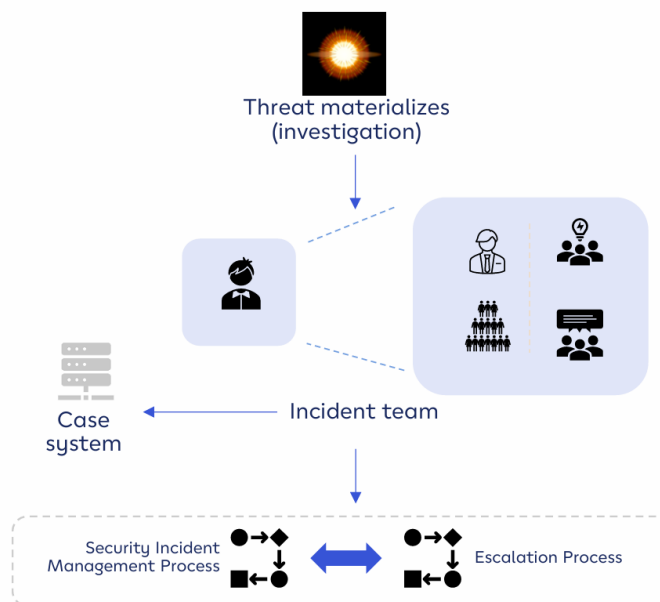


Figure 3.3: Incident Response Process

Every stage of this process must be meticulously documented. This is typically managed through a case management system, where the incident team records investigation details and categorizes the event as benign activity, a false positive, or a confirmed threat, along with the corresponding remediation steps. Depending on the organization’s infrastructure and tooling preferences, a ticketing system—such as the example shown in Figure 3.2—may also be utilized for reporting and documentation purposes.



### 3.1.3 Roles and Responsibilities

The effective operation of SOC technologies depends on clearly defined roles and responsibilities. Typical roles include SOC managers, security analysts, security engineers, threat hunters, and forensic investigators [11], all of whom collaborate to detect, analyze, and respond to security threats in real time. The SOC Manager oversees overall operations, ensuring that policies, workflows, and response activities are effectively coordinated and aligned with organizational objectives. Security analysts form the operational core of the SOC, continuously monitoring alerts, investigating suspicious activity, and executing response procedures to contain and mitigate threats. Security engineers support these activities by maintaining and optimizing the technical infrastructure, including configuring, tuning, and integrating detection and response tools.

Threat Hunters adopt a proactive approach by searching for hidden or emerging threats that may evade automated detection and routine monitoring, using advanced analysis of patterns and indicators. Forensic Investigators conduct in-depth examinations of security incidents, preserving and analyzing digital evidence to identify root causes and support remediation efforts. Collectively, these roles enable a SOC to respond effectively to immediate security events while continuously improving incident response capabilities and strengthening the organization's overall defensive posture.

## 3.2 Operational Security Challenges

Maintaining continuous monitoring imposes significant operational demands, as security analysts must process large volumes of logs and alerts to distinguish genuine threats from false positives. For instance, an EDR system may flag anomalous activity on a host that is ultimately determined to be benign. Excessive alert volumes of that kind often lead to analyst fatigue, undermining both operational efficiency and defensive effectiveness. This challenge is notably pronounced within the telecommunication sector, where security teams must oversee not only traditional Information Technology (IT) environments but also Operational Technology (OT), including critical core network elements. The integration of 5G technologies further intensifies this complexity. Features such as network slicing and edge computing decentralize network architectures, thereby significantly expanding the available attack surface. Consequently, SOCs are tasked with monitoring thousands of potential entry points in real time.

Regulatory requirements, such as the European Union's NIS2 Directive, increase the pressure of monitoring many entry points by establishing timelines for incident reporting. Upon the detection of a significant incident, organizations must submit an initial notification to a national authority or Computer Security Incident Response Team (CSIRT) within 24 hours, followed by an intermediate report assessing severity and impact within 72 hours. Achieving compliance becomes increasingly difficult as the interval between a threat actor's initial access and the completion of an intrusion continues to decrease due to the proliferation of advanced automated tools and collaboration among threat actors.

Mobile network providers face a distinct challenge regarding the limited availability of specialized security community support. While standard enterprises focus primarily on securing conventional IT infrastructure and ubiquitous protocols such as Server Message Block (SMB), which are extensively monitored and discussed in public threat intelligence, mobile network operators must manage niche underlying infrastructures and protocols, such as SS7 and Diameter. Because these protocols are sector-specific, there is a marked scarcity of shared intelligence and collaborative defense strategies on broader community platforms.



Furthermore, as providers of critical national infrastructure, MNO security teams face threat profiles that are significantly more sophisticated than those of average commercial entities. State-sponsored actors frequently target these networks to achieve strategic national disruption. Benefiting from sovereign backing, these groups are often well-resourced and highly skilled, and they leverage zero-day exploits engineered specifically for mobile network infrastructure. In the security domain, a "zero-day" refers to a newly discovered vulnerability for which no patch or mitigation currently exists. This poses a formidable challenge: state-sponsored adversaries identify these flaws, keep them confidential while developing exploits, and execute attacks before the vulnerability is publicly disclosed or remediated, making detection difficult.

## 4 Automation and Orchestration

This chapter examines the critical role of automation and orchestration in sustaining robust information security postures. While the automation of security workflows offers significant operational advantages, it also introduces certain risks and structural limitations.

### 4.1 Automation vs Orchestration

Automation, as defined by Splunk, "focuses on handling individual, repetitive IT tasks without human intervention, delivering consistent and efficient results" [13]. As established in the preceding chapter, such capabilities are vital to operational security, particularly within the telecommunications sector. A representative example of an individual repetitive task is the search for a specific subject line across thousands of employee mailboxes during a widespread phishing campaign. Automating this process via an email gateway is essential, as manual intervention would impose prohibitive time and resource demands on an incident response team. Common implementation methods for automating tasks include script-based, event-driven, and scheduled execution models. Table 4.1 contains the definitions for these modes of automation along with practical examples of how they can be used.

| Mode of Automation      | Definition                             | Examples                          |
|-------------------------|----------------------------------------|-----------------------------------|
| Script-based Automation | Executable programs that perform tasks | Bash/Powershell, Python           |
| Event-driven Automation | Automation triggered by events         | SIEM, EDR and NDR alerts          |
| Scheduled Automation    | Tasks triggered at a scheduled time    | Cronjobs, Windows Task Scheduler, |

Table 4.1: Modes of Automation

In contrast, orchestration "coordinates multiple automated tasks across systems and environments, enabling seamless end-to-end workflow management" [13]. Utilizing the aforementioned phishing scenario, orchestration facilitates the integration of the entire response cycle following the initial alert. For example, a malicious URL detected within an email triggers an alert in the Security Information and Event Management (SIEM) system, which subsequently directs a web proxy to block the connection. Simultaneously, the URL is cross-referenced against threat intelligence services, such as VirusTotal, to obtain a definitive reputation report.

If the proxy fails to intercept the connection or if the URL is confirmed as malicious, further automated response actions are initiated. These may include enterprise-wide mailbox searches to identify and remediate correlated subject lines. This process necessitates interoperability among disparate security tools, which is achieved through the integration of Application Programming Interfaces (APIs). Rather than automating a singular, isolated task, orchestration synchronizes multiple automated tasks across different domains at machine speed. Consequently, the security analyst is provided with a comprehensive notification detailing the detection, the automated remedial actions taken, and a finalized report for review and case closure, assuming no human-in-the-loop approval is required for certain steps.

## 4.2 Artificial Intelligence in Automation and Orchestration

Currently, artificial intelligence serves as a foundational component for developing automation and orchestration frameworks. Large Language Models (LLMs), a specialized subset of AI, enable the generation of various technical assets, including scripts for repetitive tasks and detection logic for Security Information and Event Management (SIEM) systems. By automating these processes, LLMs significantly reduce the time security analysts must dedicate to manual configuration.

These generative models are often deployed via conversational interfaces, such as Google's Gemini, which allow users to provide instructions using natural language. Beyond simple chatbots, the emergence of agentic AI represents a shift toward autonomous systems capable of executing recurring tasks. These agents can be configured to manage routine workflows and may eventually handle complex orchestration, provided the analyst retains oversight.

However, implementing agentic AI at this scale requires models to access organizational data, which often contains sensitive information. Consequently, large-scale deployment is advisable only if the models are hosted on-premises or within local infrastructure, isolated from public cloud providers. Utilizing and tailoring open-source models offers a viable path for organizations to maintain this level of control while leveraging AI capabilities.

## 4.3 Interoperability and Integration Challenges

Security vendors have addressed the requirements for automation and orchestration by developing Security Orchestration, Automation, and Response (SOAR) platforms. A SOAR platform serves as the central engine for executing the automated workflows and orchestrated sequences previously described. However, these platforms often suffer from vendor lock-in, as the playbooks are frequently proprietary. Consequently, a playbook developed for one environment, such as Splunk SOAR, cannot be imported or integrated into a competing platform without significant re-engineering to align with the alternative vendor's specifications and syntax.

## 4.4 Benefits and Risks

While automation and orchestration are highly desirable objectives, their implementation necessitates a careful evaluation of inherent trade-offs. The following analysis examines these considerations using a benefits-and-risks matrix, categorized by four critical dimensions: speed, scale, consistency, and integration.

| Feature     | Benefits                                                                | Risks                                                           |
|-------------|-------------------------------------------------------------------------|-----------------------------------------------------------------|
| Speed       | Reduces Mean Time to Detect (MTTD) and Mean Time to Respond (MTTR)      | An error in a step leads to cascading errors at machine speeds. |
| Scale       | Handles thousands of alerts daily                                       | Requires constant maintenance and tuning                        |
| Consistency | Tasks can be performed in a standardized and predictable way            | Static rules break when an attacker changes tactics.            |
| Integration | Orchestration links all the essential tools together for quick response | High complexity and cost required to build and maintain SOARs   |

Table 4.2: Benefits and Risks of Automation and Orchestration

This comparison, summarized in Table 4.2, provides a structured overview of the operational implications of deploying these automations.

## **4.5 Limitations of Current Automation Approaches**

A fundamental constraint of automation is its inability to replicate human judgment when encountering scenarios that deviate from established patterns. Because automated systems rely primarily on predefined signatures and heuristic models to facilitate decision-making, they are often unable to identify zero-day exploits or polymorphic malware specifically engineered to alter their behavioral characteristics to evade detection.

Furthermore, event-driven automation designed to streamline threat detection can function as a double-edged sword, as its effectiveness is entirely contingent upon the underlying detection logic. In the absence of rigorous filtering and prioritization within these logical frameworks, systems may generate an unmanageable volume of alerts, many of which are false positives. As established in previous chapters, this phenomenon imposes a significant burden on security analysts, leading to operational fatigue and potentially obscuring genuine threats.

## 5 Collaborative Defense and Information Sharing

The 2021 FluBot malware campaign highlights the critical importance of cooperation in addressing large-scale security threats. FluBot is an Android-based spyware that propagates through SMS phishing campaigns and infected millions of devices worldwide, enabling the theft of sensitive information such as banking credentials. Collaboration is particularly vital for mobile network providers, as attackers frequently deploy similar, if not identical, attack techniques against multiple operators simultaneously. As critical infrastructure operators, MNOs represent high-value targets, and isolated defensive efforts are often insufficient.

In the case of FluBot, individual Mobile Network Operators (MNOs) faced significant challenges in mitigating the threat due to the malware's use of a Domain Generation Algorithm (DGA). This algorithm continuously generated a pseudo-random list of potential command-and-control (C2) domains each month, rendering traditional blacklisting approaches ineffective. Once a specific C2 domain was identified, the attackers attempted to register other domains from the generated list; those that were successfully registered would then replace the blocked or identified domains. Infected devices subsequently attempted to contact these new domains automatically, bypassing the need for manual updates. Consequently, mitigation required reverse-engineering the malware to proactively block the domains it generated. This effort necessitated close collaboration with MNOs and culminated in a coordinated international law enforcement operation involving authorities from 11 countries, which ultimately disrupted the campaign. [14].

The FluBot case serves as a quintessential example of how sophisticated cyberattacks can overwhelm the mitigation capabilities of individual organizations. Because of its scale and technical complexity, neutralizing the threat required extensive cross-border collaboration, involving both private-sector entities and a global coalition of nations. This chapter will discuss some features and platforms used for collaboration.

### 5.1 Threat Intelligence

Threat intelligence comprises data collected, analyzed, and organized within specialized platforms to understand the motives, techniques, tactics, and procedures (TTPs) employed by adversaries. This intelligence serves as a cornerstone for collaboration within the security community and is primarily diagnostic in nature. Modern security analysts are not required to manually aggregate Indicators of Compromise (IoCs) from disparate websites, thanks to the Structured Threat Information Expression (STIX) format and the Trusted Automated Exchange of Intelligence Information (TAXII) transport mechanism.

STIX provides a standardized JSON schema that represents threat intelligence in a consistent, machine-readable format. Complementing this, TAXII serves as the application-level protocol for transporting STIX data over HTTPS. TAXII defines two primary services to facilitate information sharing: Collections and Channels. A Collection refers to a repository of threat intelligence objects hosted on a server, whereas a Channel enables the dissemination of that intelligence to subscribers. As illustrated in Figure 5.1, a producer hosts threat intelligence objects on a TAXII server, which a TAXII client(consumer) subsequently requests. By subscribing to these TAXII servers or channels, clients automatically

receive continuous updates whenever new data is uploaded. These streams of threat intelligence data are known as TAXII feeds and they enable security tools such as SIEMs to ingest and utilize threat intelligence dynamically.

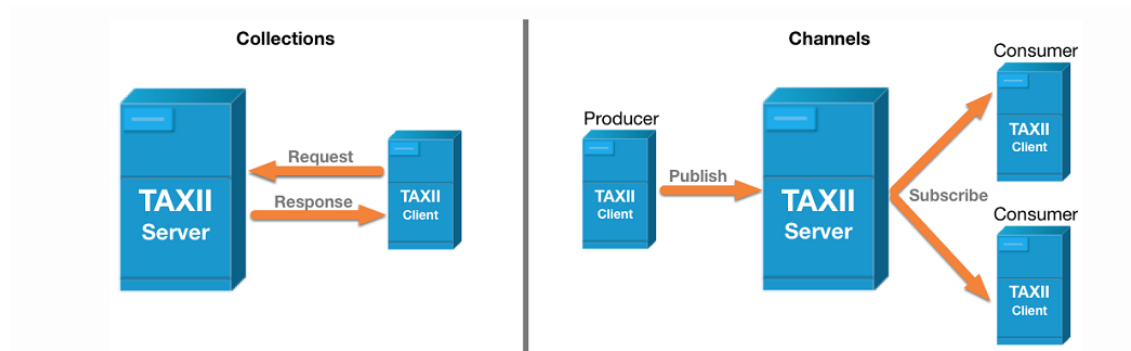


Figure 5.1: TAXII

Threat Intelligence is often classified into three categories: Tactical Threat Intelligence, Operational Threat Intelligence, and Strategic Threat Intelligence.

### 5.1.1 Tactical Threat Intelligence

Tactical intelligence focuses on immediate operational actions, primarily through the identification of indicators of compromise (IoCs) such as malicious IP addresses and domains. This level of intelligence is frequently integrated into security infrastructure to automate detection logic. For example, security tools may generate alerts when an endpoint attempts to access a domain listed in a TAXII feed or another IoC subscription service.

In tactical threat intelligence, rapid response is essential because attackers can readily modify these indicators once they are detected. The Flubot incident illustrates this challenge: although investigators reverse-engineered the domain generation algorithm (DGA) to block command-and-control communications, attackers could circumvent these measures by slightly adjusting the algorithm or rotating IP addresses.

Consequently, industry best practices suggest monitoring the longevity of IoCs within intelligence feeds. Indicators are typically considered relevant for approximately 30 days, as older data often loses its utility. While file hashes remain technically valid indefinitely, attackers frequently employ polymorphism to ensure that file hashes differ for each new victim, further limiting the long-term effectiveness of static tactical indicators.

### 5.1.2 Operational Threat Intelligence

Operational threat intelligence represents an advancement on tactical intelligence, offering a broader, more technical perspective by focusing on the identities of threat actors and their specific tactics, techniques, and procedures (TTPs). This level of intelligence enables SOC teams to identify prevalent threat actors within their industry, analyze their behavior, and develop robust strategies for detection, mitigation, and prevention. Threat modeling frameworks are frequently employed for this purpose. The MITRE ATT&CK framework, for instance, organizes various TTPs into a structured classification to support the security community's use of operational intelligence. The framework is designed for intuitive navigation: a user first identifies a high-level tactic, such as **"Initial Access,"** as seen in Figure 5.2, which then reveals specific techniques, such as the 11 different methods attackers may use to gain entry into an environment.

Selecting a specific technique from Figure 5.2, such as Phishing, provides detailed information regarding execution methods, as well as specific mitigation and detection strategies. While the availability of this public information may lead some to question the necessity of internal playbooks, the role of the security analyst remains critical. It is at the analyst's discretion to identify the correct TTPs relevant to their specific environment. Furthermore, this intelligence must be synthesized to develop high-quality detection logic, scripts, and response artifacts, all of which depend heavily on the experience, technical background, and unique security perspective of the individual analyst.

| MITRE   ATT&CK                                                                           |                               |                                   |                                        |                                          |                                                 |                                         |                                                |                                   |                                     |
|------------------------------------------------------------------------------------------|-------------------------------|-----------------------------------|----------------------------------------|------------------------------------------|-------------------------------------------------|-----------------------------------------|------------------------------------------------|-----------------------------------|-------------------------------------|
| Matrices ▾ Tactics ▾ Techniques ▾ Defenses ▾ CTI ▾ Resources ▾ Benefactors Blog Search Q |                               |                                   |                                        |                                          |                                                 |                                         |                                                |                                   |                                     |
| Reconnaissance                                                                           | Resource Development          | Initial Access                    | Execution                              | Persistence                              | Privilege Escalation                            | Defense Evasion                         | Credential Access                              | Discovery                         | Lateral Movement                    |
| 11 techniques                                                                            | 8 techniques                  | 11 techniques                     | 17 techniques                          | 23 techniques                            | 14 techniques                                   | 47 techniques                           | 17 techniques                                  | 34 techniques                     | 9 techniques                        |
| Active Scanning (3)                                                                      | Acquire Access                | Content Injection                 | Cloud Administration Command           | Account Manipulation (7)                 | Abuse Elevation Control Mechanism (6)           | Abuse Elevation Control Mechanism (6)   | Adversary-in-the-Middle (4)                    | Account Discovery (4)             | Exploitation Remote Session         |
| Gather Victim Host Information (4)                                                       | Acquire Infrastructure (8)    | Drive-by Compromise               | Command and Scripting Interpreter (13) | BITS Jobs                                | Access Token Manipulation (5)                   | Access Token Manipulation (5)           | Brute Force (4)                                | Application Window Discovery      | Internal Spearphishing              |
| Gather Victim Identity Information (3)                                                   | Compromise Accounts (3)       | Exploit Public-Facing Application | Container Administration Command       | Boot or Logon Autostart Execution (14)   | Account Manipulation (7)                        | Build Image on Host                     | Credentials from Password Stores (6)           | Browser Information Discovery     | Lateral Tool Transfer               |
| Gather Victim Network Information (6)                                                    | Compromise Infrastructure (8) | External Remote Services          | Deploy Container                       | Boot or Logon Initialization Scripts (5) | Boot or Logon Autostart Execution (14)          | Debugger Evasion                        | Exploitation for Credential Access             | Cloud Infrastructure Discovery    | Remote Service Session Hijacking    |
| Gather Victim Org Information (4)                                                        | Develop Capabilities (4)      | Hardware Additions                | ESXi Administration Command            | Cloud Application Integration            | Boot or Logon Initialization Scripts (5)        | Delay Execution                         | Forced Authentication                          | Cloud Service Dashboard Discovery | Remote Services                     |
| Phishing for Information (4)                                                             | Establish Accounts (3)        | Phishing (4)                      | Replication Through Removable Media    | Compromise Host Software Binary          | Create or Modify System Process (5)             | Deobfuscate/Decode Files or Information | Forge Web Credentials (2)                      | Cloud Service Discovery           | Replication Through Removable Media |
| Search Closed Sources (2)                                                                | Obtain Capabilities (7)       | Stage Capabilities (6)            | Supply Chain Compromise (3)            | Create Account (3)                       | Domain or Tenant Policy Modification (2)        | Deploy Container                        | Input Capture (4)                              | Cloud Storage Object Discovery    | Software Deployment Tools           |
| Search Open Technical Databases (5)                                                      | Trusted Relationship          | Valid Accounts (4)                | Poisoned Pipeline Execution            | Create or Modify System Process (5)      | Event Triggered Execution (18)                  | Direct Volume Access                    | Modify Authentication Process (9)              | Container and Resource Discovery  | Debugger Evasion                    |
| Search Open Websites/Domains (3)                                                         | Wi-Fi Networks                | Scheduled Task/Job (5)            | Serverless Execution                   | Event Triggered Execution (18)           | Event Triggered Execution (18)                  | Email Spoofing                          | Multi-Factor Authentication Interception       | Device Driver Discovery           | Domain Trust Discovery              |
| Search Threat Vendor Data                                                                |                               |                                   |                                        | Exclusive Control                        | Exploitation for Privilege Escalation           | Execution Guardrails (2)                | Multi-Factor Authentication Request Generation | File and Directory Discovery      | File and Directory Discovery        |
| Search Victim-Owned Websites                                                             |                               |                                   |                                        | External Remote Services                 | File and Directory Permissions Modification (2) | Exploitation for Defense Evasion        | Log Enumeration                                | Group Policy Discovery            | Local Storage Discovery             |

Figure 5.2: Mitre Att&ck Framework

In the telecommunications sector, for example, the group known as Salt Typhoon represents a persistent threat. Operational intelligence is utilized to identify the specific TTPs associated with such organizations, allowing defenders to fortify infrastructure against these known methods as a fundamental security baseline. Mitre ATT&CK, in this case, may not encompass all TTPs used against MNOs; another threat model framework, Bhadra, focuses on telecommunications. Following the same scenario, identifying the tactic **"Initial Access"** in Figure 5.3 yields different technique options than those identified by the MITRE attack. It presents techniques such as **"SIM-based compromise"**, etc., which cover potential TTPs that industry-specific persistent threat actors might use against the MNOs.

A significant advantage of operational intelligence is its durability compared to the short-lived nature of tactical intelligence. Because altering established tactics and techniques requires considerable effort and resources from an adversary, identifying these TTPs and implementing corresponding preventive measures can effectively neutralize a threat actor's capabilities for an extended period. Forcing attackers to update their TTPs increases the operational cost and complexity of their campaigns, which serves as a powerful deterrent against less-equipped or resource-constrained actors.



| Attack Mounting                             |                                                  |                                           | Attack Progression              |                                                           |                                         |                                        | Attack Results                |                                              |
|---------------------------------------------|--------------------------------------------------|-------------------------------------------|---------------------------------|-----------------------------------------------------------|-----------------------------------------|----------------------------------------|-------------------------------|----------------------------------------------|
| Reconnaissance                              | Initial Access                                   | Persistence                               | Discovery                       | Lateral Access                                            | Standard Protocol Misuse                | Defense Evasion                        | Collection                    | Impact                                       |
| Perimeter mapping of network infrastructure | Access from UE                                   | Infecting UE software or hardware         | Operator network mapping        | Exploiting interfaces within the operator network         | SS7-based techniques                    | Stealth scanning                       | Administrator credentials     | Location tracking                            |
| Perimeter mapping for mobiles               | SIM-based compromise                             | Infecting network elements                | Core network function scanning  | Exploiting roaming and interconnection                    | Diameter-based techniques               | Firewall bypass                        | Operator-specific identifiers | Personal information disclosure              |
| Out-of-band intelligence gathering          | Access from radio access network                 | Command and control channels              | Internal intelligence gathering | Exploiting interworking                                   | Routing information querying techniques | Denylist evasion                       | Operator data                 | Mass information gathering                   |
|                                             | Access from inside the operator network          | Exploiting hard-to-repair vulnerabilities | Internal UE scanning            | Core-network access from radio network                    | GTP-based techniques                    | Malware anti-detection techniques      | User credentials              | Unwanted communication                       |
|                                             | Access from partner mobile network               | Knowledge of keys and credentials         |                                 | Exploiting platform- and service-specific vulnerabilities | IP-based techniques                     | Signaling-protocol downgrading         | User-specific identifiers     | Call, message and data interception          |
|                                             | Access from operator's IP network infrastructure |                                           |                                 | Exploiting implementation flaws in 3GPP protocols         | SIP-based techniques                    | Radio-link downgrading and redirection | Communication metadata        | Failure of mobile network as trusted channel |
|                                             | Access from the public Internet                  |                                           |                                 |                                                           | AKA-related techniques                  |                                        |                               | Billing discrepancies                        |
|                                             | Compromised insiders and human errors            |                                           |                                 |                                                           | Cryptographic techniques                |                                        |                               | Denial of Service                            |
|                                             | Supply chain attacks                             |                                           |                                 |                                                           |                                         |                                        |                               |                                              |

Figure 5.3: Bhadra Framework

### 5.1.3 Strategic Threat Intelligence

Strategic threat intelligence focuses on high-level trends, including global threat shifts and their specific implications for an organization's industry. This intelligence evaluates how emerging risks influence the effectiveness of established tools, systems, and internal policies. Such insights are essential for senior leadership, including CEOs, CISOs, and executive managers, who oversee budgetary allocations, strategic direction, and security training. To stay informed, these decision-makers often participate in trade associations, professional communities, and industry forums. These engagements allow them to monitor the geopolitical landscape and evolving regulatory requirements, both of which are critical for shaping robust organizational policies.

## 5.2 Information Sharing Platforms

Beyond the categorization of threat intelligence, it is necessary to examine the information-sharing platforms where this data is hosted and disseminated. To understand these platforms, one must first define the hierarchy of the data being shared.

Indicators of Compromise (IoCs) serve as the fundamental unit of threat intelligence. These progress into Tactics, Techniques, and Procedures (TTPs), which provide deeper operational context. At the highest level of this hierarchy are playbooks. A playbook acts as a comprehensive container that integrates both IoCs and TTPs, or presents highly detailed versions of each. Consequently, a sufficiently detailed and structured grouping of IoCs can constitute a playbook in its own right. The platforms discussed in this section vary in scope: some focus on tactical intelligence or operational intelligence, while others are comprehensive enough to include strategic intelligence.

### 5.2.1 Malware Information Sharing Platform (MISP)

The Malware Information Sharing Platform (MISP) is an open-source framework originally designed to facilitate the exchange of malware-related Indicators of Compromise (IoCs). It has since evolved into a versatile threat intelligence platform capable of hosting a diverse range of intelligence types previously discussed. The utility of MISP is primarily derived

from its structured data model. The platform organizes information into a clear hierarchy consisting of Events, Attributes, and Objects, which is listed in the data models tab in Figure 5.4

An Event serves as a contextual container for data related to a specific incident or report. The fundamental components of an Event are known as Attributes; these typically include IoCs such as IP addresses or domains, as outlined in the section on tactical threat intelligence. MISP assigns these Attributes specific categories (e.g., Network activity) and types (e.g., ip-src), providing the necessary context for automated processing. Objects further refine this structure by grouping multiple Attributes to represent complex entities that a single attribute cannot sufficiently describe. For example, a File object can aggregate several Attributes, such as a filename, file size, and various cryptographic hashes, to provide a comprehensive representation of a real-world threat actor's toolkit.

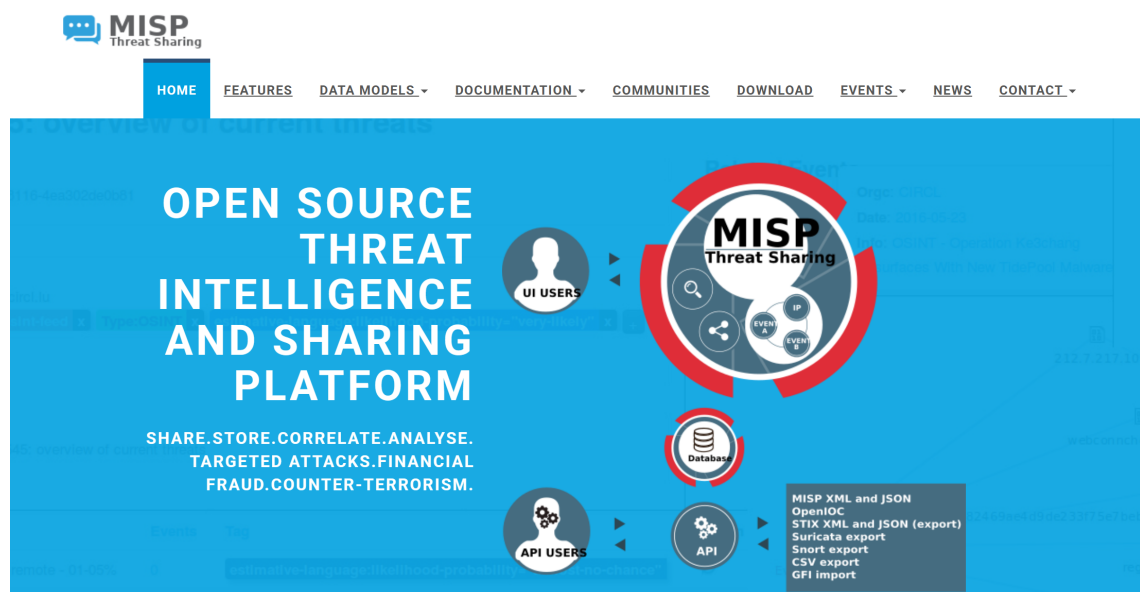


Figure 5.4: MISP [15]

In Figure 5.4, the Features tab displays the various categories of threat intelligence available in MISP, organized through a system of tags and taxonomies. This intelligence is often curated within specialized communities that serve distinct industries or organizational entities. Furthermore, MISP provides a repository of security playbooks designed to address frequent use cases by operationalizing the intelligence stored on the platform. These playbooks are primarily hosted on GitHub as Jupyter notebooks, combining instructional Markdown text and graphical workflows with executable Python code. This integration allows analysts to interact directly with the MISP API, typically via the PyMISP library, to automate data enrichment and incident response tasks.

## 5.2.2 GITHUB

GitHub is a web-based platform designed for project storage, management, and collaboration. While its primary function is version control in fields such as software development, it is also utilized within the domain of threat intelligence. For instance, MISP playbooks are hosted on GitHub [16], as are various other human-readable playbooks, including those from Société Générale. One of the Société Générale playbooks will be employed in a subsequent chapter to evaluate the conversion process into a machine-readable format.

## 5.2.3 MATTERMOST

Mattermost is an open-source collaborative platform that organizations can deploy on-premises or within a private cloud environment. By allowing for self-hosting, the platform ensures data sovereignty and safeguards user privacy. Mattermost aims to mitigate tool fragmentation by consolidating real-time communication, project management, and incident response into a single interface through three primary features: Channels, Boards, and Playbooks.

Channels facilitate interaction and discussion among members of an association, community, or organization, as illustrated in Figure 5.5. This feature is particularly effective for disseminating information and managing strategic threat intelligence, providing a dedicated space where members can discuss the broader trajectory of information security and other organizational matters.

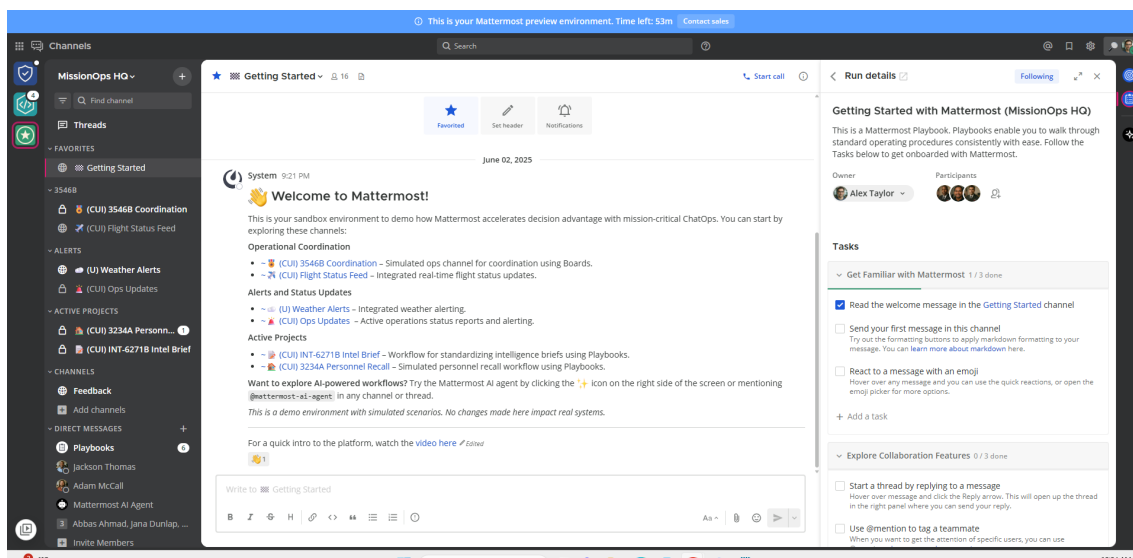


Figure 5.5: Mattermost Channel[17]

Figures 5.6 and 5.7 demonstrate the Boards feature, which provides integrated project management for platform users. As these figures indicate, the feature allows for the assignment of responsibilities and tracks the progression of tasks through various status phases. For example, Figure 5.6 displays tasks labeled "To Do" and "In Progress," identifying the individuals responsible for execution. It further categorizes tasks by function—such as "Detection"—and specifies the intended impact, such as "Noise Reduction."

Figure 5.7 reflects the same structure but captures later stages of the workflow, such as "In Review" and "Done," to conclude the project management cycle. A significant advantage of this integrated approach is the ability to link Channels directly to Boards; when a Channel is connected, its members are automatically synchronized with the Board, ensuring flexible and efficient task distribution across the team.

**Threat Discussion Tasks**

1. List View    Properties    Group by: Status    Filter    Sort

| Name                                                     | Status      | Owner          | Function         | Impact Type            |
|----------------------------------------------------------|-------------|----------------|------------------|------------------------|
| <b>To do</b> 8                                           |             |                |                  |                        |
| Tune alert for admin logins from new devices             | TO DO       | Huzalfa Anas   | DETECTION        | Noise Reduction        |
| Reverse engineer LOLBin payload for signature dev        | TO DO       | Austin Arthur  | MALWARE ANALYSIS | Detection Engineering  |
| Retrohunt for RDP botnet IPs across last 30 days         | TO DO       | Koen Chegg     | THREAT INTEL     | Retrohunt              |
| Evaluate OneNote malware tooling options                 | TO DO       | Austin Arthur  | MALWARE ANALYSIS | Tooling Research       |
| Draft SOC briefing on Okta phishing wave                 | TO DO       | Mary Cruz      | AWARENESS        | Internal Comms         |
| Create Sigma rule for HR-themed phishing patterns        | TO DO       | Harper Stevens | DETECTION        | Email Security         |
| Correlate reused GitHub handles with recent malware ...  | TO DO       | Koen Chegg     | THREAT INTEL     | Actor Tracking         |
| Build emulated fake login pages for phishing TTP testing | TO DO       | Austin Arthur  | RED TEAM         | Simulation Development |
| <b>In Progress</b> 5                                     |             |                |                  |                        |
| Update tag structure for threat database entries         | IN PROGRESS | Harper Stevens | DOCUMENTATION    | Standardization        |
| Run IOC enrichment on QakBot C2 domains                  | IN PROGRESS | Koen Chegg     | THREAT INTEL     | Enrichment             |

COUNT 20

Figure 5.6: Mattermost Boards[17]

**Threat Discussion Tasks**

1. List View    Properties    Group by: Status    Filter    Sort

| Name                                                       | Status      | Owner          | Function       | Impact Type             |
|------------------------------------------------------------|-------------|----------------|----------------|-------------------------|
| <b>In Progress</b> 3                                       |             |                |                |                         |
| Investigate failed AWS login pattern for spray attempt     | IN PROGRESS | Adam McCall    | SOC OPS        | Authentication Analysis |
| Create dashboard for phishing report trends by weekday     | IN PROGRESS | Mary Cruz      | AWARENESS      | Metrics                 |
| Analyze PowerShell payload from user-submitted invoice     | IN PROGRESS | Austin Arthur  | IR/FORENSICS   | Payload Analysis        |
| <b>In Review</b> 3                                         |             |                |                |                         |
| Finalize Azure anomaly detection logic for deployment      | IN REVIEW   | Huzalfa Anas   | CLOUD SECURITY | Behavioral Analytics    |
| Develop Splunk rule for DNS tunneling detection            | IN REVIEW   | Warren Daniel  | DETECTION      | DNS Monitoring          |
| Create checklist for responding to CVE exploitation alerts | IN REVIEW   | Jackson Thomas | PROCESS        | Playbook Enhancement    |
| <b>Done</b> 4                                              |             |                |                |                         |
| Whitelist test VMs for SSH brute force alert               | DONE        | Harper Stevens | DETECTION      | Alert Tuning            |
| Review SOAR auto-block policy for red team exclusions      | DONE        | Warren Daniel  | AUTOMATION     | Simulation Readiness    |
| Integrate Red Canary phishing tests into lab workflow      | DONE        | Harper Stevens | DETECTION      | Testing Automation      |
| Extract Indicators from PDF macro sample                   | DONE        | Elvin Bond     | IR/FORENSICS   | IOC Extraction          |

COUNT 20

Figure 5.7: Mattermost Boards[17]

The Playbooks feature within the Mattermost platform provides a structured, step-by-step set of activities for coordinating complex workflows. During an assessment using a temporary demo account, it was observed that the "Getting Started with Mattermost" playbook is automatically triggered upon account creation to guide user onboarding, as shown in the "In Progress" status in Figure 5.8.

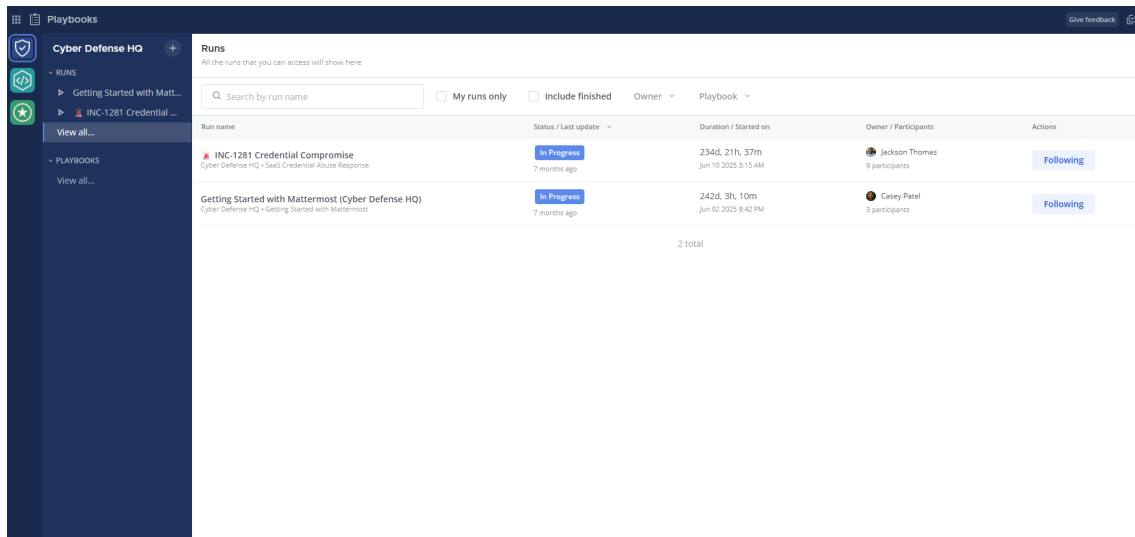


Figure 5.8: Mattermost Playbook[17]

This functionality is equally applicable to incident response. When a security event occurs, a preconfigured playbook can be triggered to automatically initiate a dedicated incident channel and generate a checklist to document the proceedings. Figure 5.9 illustrates the playbook creation interface, which includes several customizable sections. For example, users can define specific tasks for different incident types, such as automatically adding an on-call engineer to the incident channel or initiating a bridge call, as depicted in Figure 5.9.

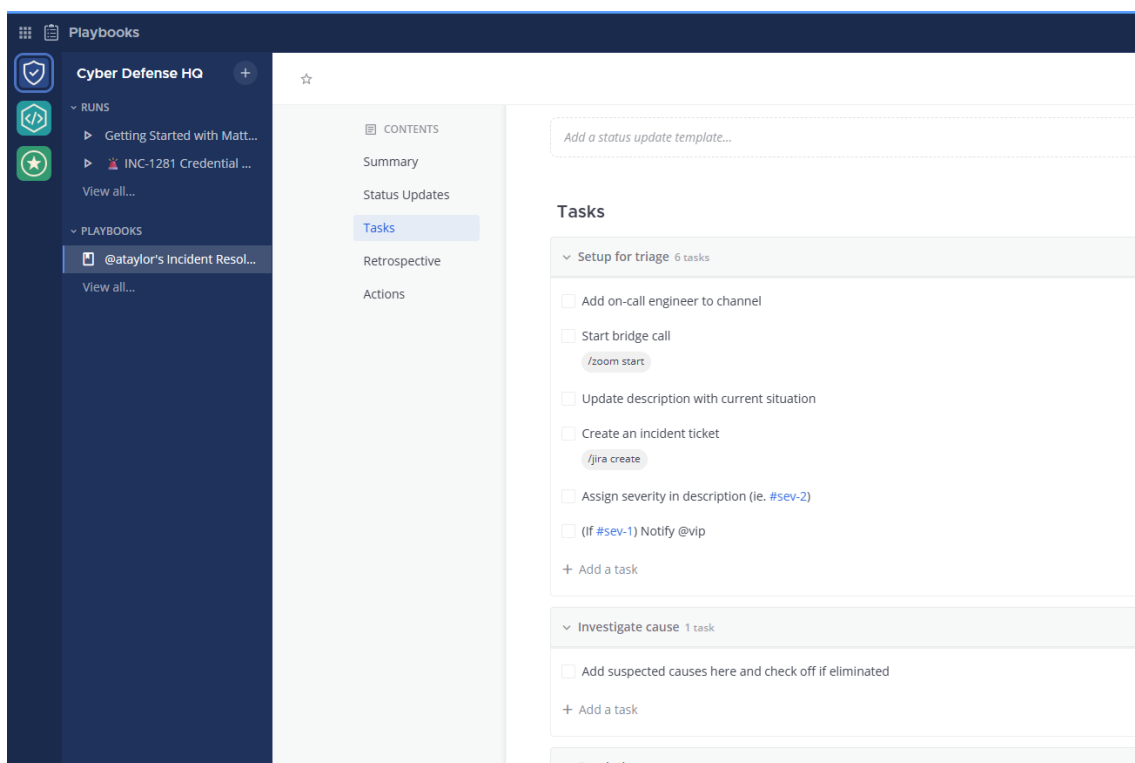


Figure 5.9: Mattermost Playbook

Ultimately, this feature enables the rapid establishment of an environment where all necessary stakeholders can collaborate. It allows for the integration of specific tasks into Boards and facilitates immediate verbal communication through integrated calls. Furthermore, the platform ensures that every action is documented, providing a comprehensive audit trail for future post-mortem analysis and regulatory compliance.

### **5.3 Collaborative Requirements using Playbooks**

Effective collaboration through playbooks necessitates adherence to specific functional requirements. In their design of a web-based system for managing shareable automated playbooks, M.A Gurabi et al. [18] identified several critical criteria that are essential to this study:

**Standardized Machine-Readable Vocabulary:** Security professionals require a shared understanding of playbooks during the exchange process, as documentation styles and levels of abstraction often vary between organizations. A standardized, machine-readable format is considered the most effective solution for ensuring interoperability, integration, and automated processing—objectives that align with the goals of the current research.

**Privacy and Confidentiality:** M.A Gurabi et al. argue that sensitive data must be identified and excluded prior to sharing. In various scenarios, they even suggest that the identities of playbook publishers should remain anonymous. Protecting such information is a foundational security practice and a core component of the CIA (Confidentiality, Integrity, and Availability) triad.

**Playbook Visualization:** Despite the importance of automation, incident handlers often prefer visual representations of playbooks, such as structured BPMN graphs, to facilitate efficient real-time decision-making. Providing a visual flow allows practitioners to quickly comprehend the logic of a received playbook, effectively bridging the gap between machine readability and human interpretation.

**Usability:** This requirement often exists in tension with privacy and confidentiality. The authors note that abstracting playbook details to meet privacy standards can diminish the playbook's effectiveness and its suitability for automated workflows. To resolve this, they suggest applying the Traffic Light Protocol (TLP) to individual steps and resources rather than to the entire playbook, thereby maintaining utility while protecting sensitive data.

## 6 Research Methodology

This chapter details the methodological framework employed to investigate the risks and benefits associated with collaborative automated security playbooks. Adopting a qualitative approach, the study seeks to capture expert perceptions, professional judgments, and nuanced contextual factors. Furthermore, it examines the underlying logic of decision-making processes while addressing the practical challenges encountered during the research and the subsequent trade-offs required to fulfill the project objectives. The study was conducted in three distinct phases: exploration (literature review), investigation (semi-structured interviews), and validation/application (expert workshop).

### 6.1 Phase I: Exploration

During this phase, a comprehensive review of scholarly literature and industry publications was conducted to establish the current state of collaboration within the security community, evaluate prevailing technologies, and identify industrial challenges. Academic databases, including DTU Findit and Google Scholar, served as the primary sources for identifying relevant research, while blog posts from industry leaders provided supplementary practical insights.

The objective of this exploration was to identify existing gaps in collaborative practices and propose a theoretical framework to address them. The literature emphasized the necessity of collaboration via automated playbooks to counter the increasing sophistication and speed of contemporary cyberattacks. The consensus within the reviewed material identified the Collaborative Automated Course of Action Operations (CACAO) specification as the leading standard for vendor-agnostic security playbooks. Consequently, the CACAO specification became a focal point for further investigation, highlighting the need for expert interviews to assess market demand and identify potential industrial alternatives that may have been overlooked during the initial exploration phase.

### 6.2 Phase II: Investigations

In this phase, semi-structured interviews were conducted to facilitate open dialogue and gather comprehensive data. The stakeholders for this investigation comprised experts from TDC NET; although the sample size was limited to three participants, their collective experience within the security operations of a major mobile network provider offered significant depth. The session was conducted in person with a manager and two security analysts, lasting approximately one hour. While a predetermined set of questions guided the interview, it evolved into a fluid discussion that revealed critical insights into industry perceptions of collaboration. Furthermore, the inclusion of the managerial perspective provided a distinct synthesis of technical expertise and strategic oversight. These findings are analyzed in detail in the following chapter.

### 6.3 Phase III: Validation

The primary objective of this phase was to evaluate the feasibility of generating CACAO security playbooks for routine tasks performed across various security team roles. To achieve this, a practical workshop was conducted with approximately 12 participants, comprising two distinct activities. The first session focused on ensuring participants possessed a foundational understanding of the CACAO specification. This stage elicited

insights from diverse professional perspectives and addressed the core research questions established at the project's inception. The second activity required participants to leverage a Large Language Model (LLM) to generate playbooks for various security tasks. This exercise aimed to determine how such tools might optimize operational processes and whether their integration would increase analysts' confidence in implementation in a production environment.

Table 6.1 summarizes the three phases, highlighting their primary characteristics and purpose.

| Phase   | Method                 | Participants | Purpose                                |
|---------|------------------------|--------------|----------------------------------------|
| Phase 1 | Literature Review      | N/A          | Identify theoretical gaps.             |
| Phase 2 | Stakeholder Interviews | 3            | Gather primary industry insights       |
| Phase 3 | Practical Workshop     | 12           | Validate findings and design solutions |

Table 6.1: Summary

## 6.4 Limitations and Consideration

At the outset of this research, a primary objective was to execute a CACAO playbook within either a production or a simulated environment. However, several constraints necessitated refining this goal. First, the project's duration was insufficient to accommodate a full-scale implementation. Second, because CACAO playbooks are in the early stages of community adoption, they are not yet integrated into most production workflows; this lack of established infrastructure makes the deployment and testing of playbooks against typical use cases exceptionally complex.

Furthermore, although simulating in a SIEM to test these playbooks was considered, the required API integrations and environment configuration proved too time-intensive. Although the environment was successfully established to validate CACAO playbooks, the effort required to integrate these systems with a SIEM was significantly underestimated. Consequently, the research focus shifted exclusively to playbook generation and to identifying characteristics of sharing that could foster broader adoption within the security community and enhance collaboration among mobile network providers. This shift was justified by the observation that technical integration is a well-defined process that specialized teams can perform once the organizational benefits of CACAO playbooks are widely recognized within the security community.

The research direction was further justified by the findings from the interview phase, which revealed that the primary challenges were rooted in organizational sentiment and risk perception rather than technical limitations. It is also important to acknowledge that the qualitative findings, derived from three individuals within a single organization (TDC NET), may be insufficient to generalize across the entire mobile network operator (MNO) sector. However, the participants suggested that the sentiments shared are likely representative of broader perspectives within the security community.



## 7 Exploration and Validation

During the exploratory phase of the project, a preliminary workflow was developed to outline a potential solution to the identified problem. Figure 7.1 illustrates the initial connection between playbooks, sharing platforms, and security infrastructure. The central objective was to transform legacy playbooks into a structured format, utilizing either a graphical user interface within Cacao Roaster or a Large Language Model (LLM), as depicted on the left portion of Figure 7.1. Once converted into a structured format, i.e., a CACAO playbook, the file is prepared for distribution. As shown on the right side of Figure 7.1, the playbook can then be uploaded to an open-source sharing platform to support the broader security community or ingested directly into security infrastructure through proprietary tools and systems.

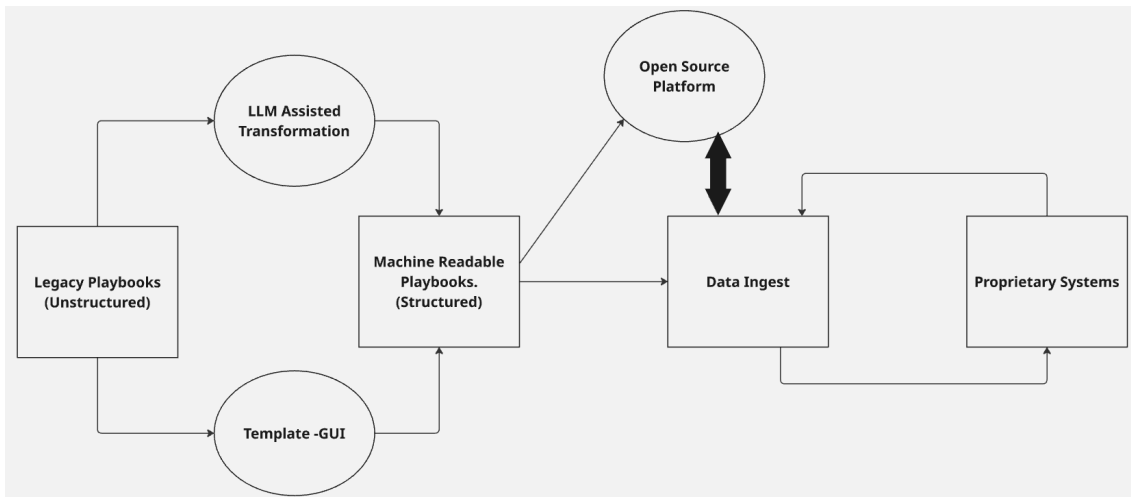


Figure 7.1: Preliminary Workflow

As discussed in Chapter 5, the exchange of threat intelligence, which includes playbooks, is an established practice. Open-source platforms already exist for this purpose, and the technology for transporting such data into proprietary systems is well supported by formats and protocols such as STIX and TAXII. Nevertheless, certain adjustments are required to facilitate collaboration through automated playbooks, and this will be discussed in this chapter.

Because CACAO has not yet achieved mainstream adoption within the security community, this research focuses on playbook generation. Without a viable method for creating these products, widespread adoption remains unlikely. The study aims to identify the requirements for generating these playbooks by first converting existing machine-readable playbooks into the CACAO format to identify flaws, limitations, and complexities inspired by the work done by M.A Gurabi et al [9] as discussed in Chapter 2.

### 7.1 Transformation of Playbooks

The transformation of a legacy playbook into a CACAO machine-readable format was based on a sample phishing playbook from Societe Generale [19]. The execution of this

transformation relied on a toolchain consisting of Docker, a chatbot, SOARCA, and CACAO Roaster. Docker was used to host the SOARCA and CACAO Roaster containers, which together enable execution of the CACAO playbook. SOARCA is an open-source security orchestrator that ingests, validates, and executes CACAO security playbooks. Functioning as an open-source Security Orchestration, Automation, and Response (SOAR) tool, it supports interfaces such as HTTPS, SSH, and OpenC2 to interact with external tools and resources. CACAO Roaster is a web application designed for CACAO playbooks, used to create, modify, and visualize them graphically. While it is intended to simplify the creation of these playbooks and is more efficient than manually drafting JSON code, the process remains relatively time-consuming. Consequently, employing a chatbot to perform the primary conversion tasks proved to be the more efficient methodology.

The legacy phishing playbook was uploaded to ChatGPT (OpenAI)[20] to facilitate the conversion. The technical approach utilized Retrieval-Augmented Generation (RAG) and persona-based prompt engineering; specifically, the CACAO schema was provided to the model alongside instructions to **"act as an expert in this field"** and **"generate a CACAO playbook that can be imported into SOARCA."** The prompt specifically directed the model to convert the source material into the standardized CACAO playbook. The resulting output is detailed in Appendix A.1.

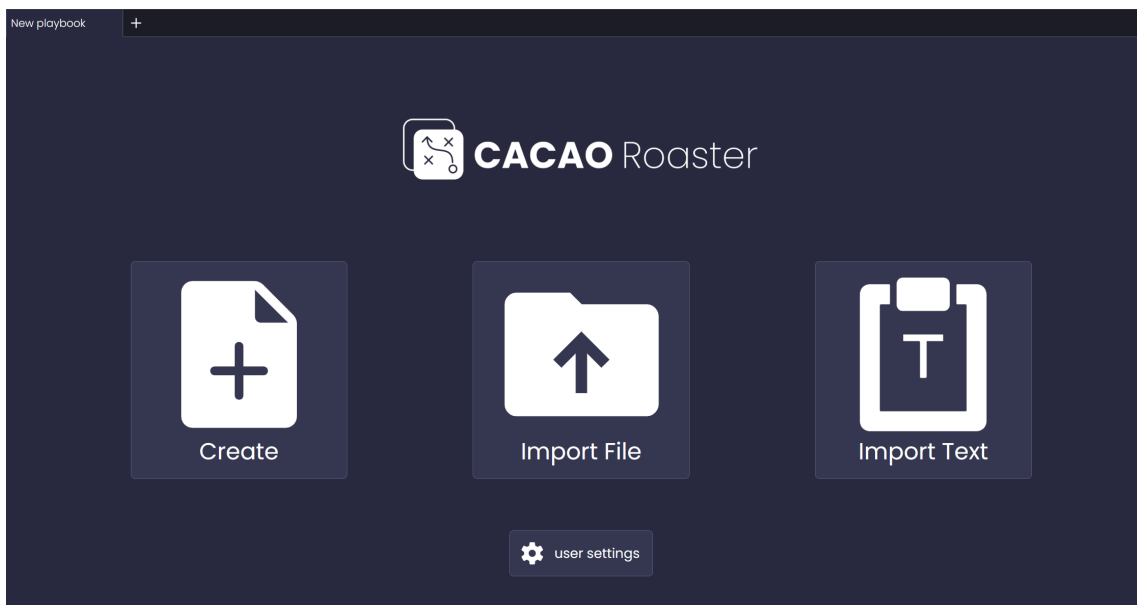


Figure 7.2: CACAO Roaster Interface

The SOARCA and CACAO Roaster instances were initiated in Docker and interconnected to facilitate the workflow. Once the chatbot generated the JSON output according to the CACAO specification, there was then the option to import into SOARCA using CACAO Roaster either by file or by pasting the text directly, as illustrated in Figure 7.2. After importing, the playbook was relayed to SOARCA for orchestration. Additionally, the **"create"** option shown in Figure 7.2 provides access to a graphical user interface, allowing for the visual construction of playbooks.



Figure 7.3: Importing Playbook using CACAO Roaster

Figure 7.3 displays the JSON code found in Appendix A.1 retrieved from the transformation of the phishing playbook and its subsequent import into SOARCA via CACAO Roaster. If the playbook does not meet the requirements for the CACAO version 2 specification, the import process fails. This mechanism in the CACAO Roaster serves as a syntax validation step, ensuring that all playbooks adhere to the formal rules of the CACAO specification prior to integration. However, this process does not include semantic validation; CACAO Roaster confirms syntactical correctness but does not verify whether the playbook’s intended logic or functional purpose is accurate.

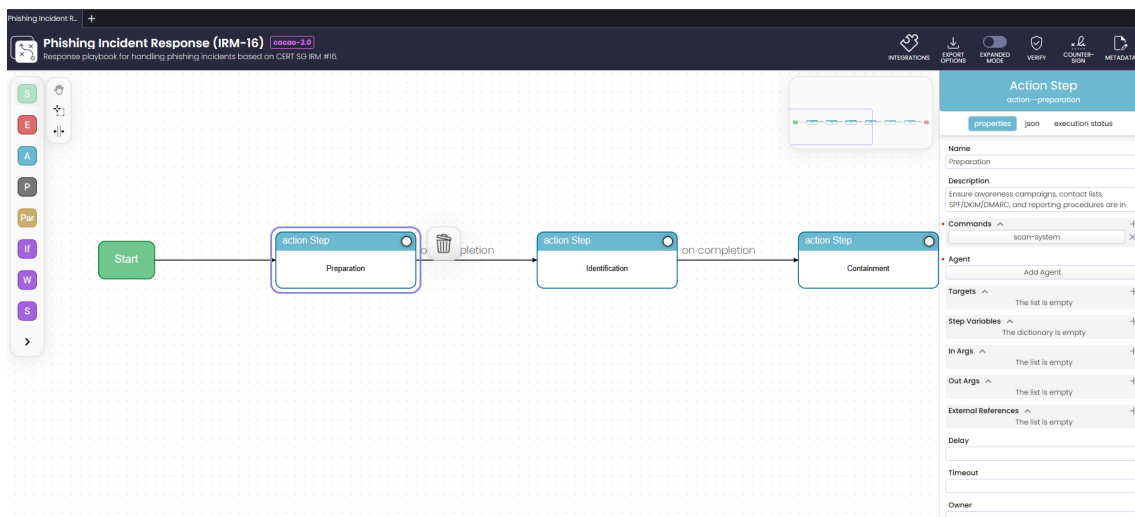


Figure 7.4: Imported Playbook

When the playbook is successfully imported, it is represented graphically as a flowchart, as shown in Figure 7.4. This makes it easier for the analyst, who is expected to use it, to quickly identify the steps in the playbook when it is a manual process, and it also makes it

easier for the playbook creator to verify that the steps are correct and that no hallucinations occurred during the chatbot-driven transformation. This playbook did not require external tools; however, if it did, the commands, agent, and targets shown on the right-hand side of Figure 7.4 would have been populated to connect with other tools, provided that the API integration is properly configured.

## 7.2 Qualitative Analysis

To understand MNOs' needs regarding collaboration, it was essential to examine in greater detail their perspectives on playbooks, community platforms, and infrastructure, and to assess the usefulness of these resources. Two major information-gathering exercises were conducted during the project. A qualitative analysis was conducted through an interview with two security analysts and a manager at TDC Net, during which the motivations for using playbooks and the need for collaboration were discussed at length. The second event involved 12 security analysts, divided into four groups at TDC Net, immediately before a practical workshop session, to obtain additional perspective through a questionnaire. The insights derived from the answers to the questions are expressed below;

### 7.2.1 Motivation for using Playbooks

The manager's rationale for creating and using playbooks was that they provide the department with a standardized methodology for threat detection and incident response, reducing reliance on individual expertise or the immediate capabilities of a security analyst. For example, a junior analyst or practitioner responding to an alert during late-shift hours may experience cognitive overload, which hinders their ability to determine the appropriate course of action.

Implementing a step-by-step procedure is therefore imperative to guarantee a consistent quality of response. The manager's opinion was that, despite the playbook's utility, many organizations still lack comprehensive playbook libraries. Championing the creation of these playbooks in any functional format is a critical first step. While this represents an initial hurdle, the necessity of such documentation is well-recognized within the security community and does not require further preliminary research.

In the second part of the information-gathering process, participants were asked whether automated playbooks could reduce MTDD and MTTR, and whether sharing playbooks among MNOs could affect MTDD and MTTR. 100% of participants responded yes to both questions, with some offering caveats. Group 2, shown in Table 7.1, agreed that MTTR would be reduced when using a shared playbook, given that the playbook was fully automated and the recipients had total control over the workflow. Group 3 stated that if there is no significant overhead in translating the received playbook to fit their infrastructure and tooling, then both MTTR and MTDD will be reduced.

Table 7.1: Responses regarding automation and playbooks.

|                | Q1                                                                                                                | Q2                                                             |
|----------------|-------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------|
| <b>Group 1</b> | Yes, all automation would lower the detect and response. Given the number of abuse cases we see on a daily basis. | Sure, it would not matter who is the author of such playbooks. |

|                | Q1                                                                                                                                                                                                               | Q2                                                                                                                                                                                                                                  |
|----------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Group 2</b> | MTTR could be reduced if this was fully automated and we had 100% control over the workflow in the business ie. Automatically blackhole IP addresses/ranges on the peering routers or locking user accounts etc. | In the ideal world where schemas/tags etc are aligned, a shared playbook from some other MNO, then the detection playbook could reduce our MTTR, aka our use cases in the security tools. Else we will have to create it ourselves. |
| <b>Group 3</b> | Yes, it can reduce the MTTR. There is a lot more flexibility, it can utilize the tooling we have in our stack.                                                                                                   | If there is not a large overhead in translation, then yes.                                                                                                                                                                          |
| <b>Group 4</b> | Yes, automated playbooks and SOAR would most likely reduce MTTR and MTTR.                                                                                                                                        | Yes!                                                                                                                                                                                                                                |

## 7.2.2 Factors that prevent sharing among MNOs

Assuming the company already has these playbooks, will they be willing to share them? The security analysts noted that it depended on several factors. One of the major concerns was that there must be a foundational level of trust within the security community in which sharing will occur, and that this trust is often more effectively established within smaller communities, where direct interaction facilitates the development of professional relationships.

These reservations stem from concerns about the leakage of internal processes and the potential exposure of operational vulnerabilities that attackers could exploit if the originating organization is identified. To examine the reciprocal of this issue, the questionnaire asked the twelve security professionals mentioned earlier whether they would trust an automated playbook provided by a colleague, an MNO in Denmark, an MNO outside of Denmark, or the Internet. By shifting the focus from sharing to adoption, this inquiry aims to address both requirements for establishing a robust sharing culture.

Table 7.2 illustrates the willingness to trust using a color-coded system: green indicates high trust, yellow represents conditional trust, and red signifies a near-total lack of trust. The data suggest that most security analysts prioritize trust in colleagues while maintaining strict distrust of unknown internet sources. This further supports the point derived from the first interview, which implied that the more interactions between the parties, the greater the likelihood of fostering trust. While Danish MNOs are viewed with some caution—resulting in a moderate trust rating—they are generally preferred to international MNOs, despite both falling within the same category. Notably, Group 4 represents an outlier, exhibiting a “zero trust” policy toward all entities. Given the diverse roles and responsibilities of the surveyed analysts, their specific professional perspectives likely influence their varying degrees of sensitivity to collaborative sharing.

The manager identified an additional factor during the interview: the absence of peer feedback can deter sharing. When a security department contributes to the community without receiving feedback or realizing mutual benefits, the incentive to share diminishes, as the effort is perceived as yielding no return. Consequently, there is less motivation to dedicate time to developing playbooks tailored for external distribution; instead, resources are redirected toward internal detection and response activities.

| Group | Colleague        | MNO in DK                                                     | MNO Outside DK                                                           | Internet            |
|-------|------------------|---------------------------------------------------------------|--------------------------------------------------------------------------|---------------------|
| 1     | Yes              | Depends on the MNO                                            | Depends on the MNO                                                       | No                  |
| 2     | Yes              | Trust in DK MNOs may be higher but still needs vetting        | Trust in MNOs outside of DK is lower than that of DK. Also needs vetting | Requires vetting    |
| 3     | Yes              | There is a degree of trust but not fully. Should be evaluated | There is a degree of trust but not fully. Should be evaluated            | Should be evaluated |
| 4     | Should be vetted | Should be vetted                                              | Should be vetted                                                         | Should be vetted    |

Table 7.2: Trust evaluation by groups

Furthermore, one analyst in the interview noted that there are currently no regulatory mandates requiring mobile network providers to share security playbooks. However, if governing bodies were to enforce regulations, such as the NIS2 Directive, that explicitly require the sharing of such playbooks, organizations would ensure compliance. This shift redefines the central issue from whether sharing is mutually beneficial to whether the various providers intend to maintain regulatory compliance.

### 7.2.3 Similar Open Source Frameworks

The other analyst noted that Sigma rules are widely used for threat actor detection because they can be easily translated into SIEM query languages and are easier for humans to read, as they are written in YAML. Since the detection logic is already written in this format and used publicly, it is important to include it to reduce the learning curve for analysts in the industry when implementing the framework. Fortunately, the CACAO specification supports sigma rules as a command in the action steps. Therefore, a combination of both is investigated.

```

1 title: Nslookup PowerShell Download Cradle
2 id: 999bff6d-dc15-44c9-9f5c-e1051bfc86e1
3 related:
4   - id: 1b3b01c7-84e9-4072-86e5-fc285a41ff23
5     type: similar
6 status: test
7 description: Detects a powershell download cradle using nslookup. This cradle
8               uses nslookup to extract payloads from DNS records.
9 references:
10  - https://twitter.com/Alh4zr3d/status/1566489367232651264
11 author: Sai Prashanth Pulisetti @pulisettis, Aishwarya Singam
12 date: 2022-12-10
13 modified: 2025-02-25
14 tags:
15  - attack.execution
16  - attack.t1059.001
17 logsource:
18   product: windows

```

```

18     category: ps_classic_start
19 detection:
20     selection:
21         Data|contains|all:
22             - 'powershell'
23             - 'nslookup'
24             - '[1]'
25         Data|contains:
26             - '-q=txt http'
27             - '-querytype=txt http'
28             - '-type=txt http'
29     condition: selection
30 falsepositives:
31     - Unknown
32 level: medium

```

From the SigmaHQ GitHub repository, a Sigma rule was selected at random and investigated, which detects a PowerShell download cradle using nslookup. [21]. The key information for this research is that the sigma rule permits including references. The links to the shared cacao playbooks can be included in this field. As the sigma rule is converted into a SIEM query language to execute the detection logic, the analyst can also retrieve the cacao playbook, which will execute the response plan for the detection. The Cacao specification has a command object that supports sigma rules. Therefore, the opposite is also true: a cacao playbook can have sigma rules embedded, which will essentially handle the detection logic.

## 7.3 Practical Session: Workshop

A practical session was conducted at TDC NET to develop playbooks, employing a methodology that differed from that used by M.A Gurabi et al. [9]. While M.A Gurabi et al. focused on converting legacy playbooks into the CACAO format, this session prioritized the direct translation of routine operational use cases and activities into playbooks via chatbots. For example, security analysts frequently retrieve vulnerability updates from the NIST website; these entries provide brief descriptions and links to resources that assist analysts in investigating, identifying, responding to, and patching specific vulnerabilities.

Consequently, one task involved addressing a specific vulnerability, **CVE-2025-5777 (CitrixBleed 2)** [22], and developing a playbook to detect and respond to associated exploits. The initial step was to provide the chatbot with foundational material on the CACAO standard. To achieve this, the CACAO v2 specification document was uploaded alongside the following prompt:

```

1  "
2  The link provided is a vulnerability information. Thoroughly go through
   the vulnerability information and discover how to identify signs of
   exploitations. With this information, the cacao version 2
   specification document attached will be used syntax-wise to create a
   cacao playbook to identify the signs of exploitation. https://nvd.nist
   .gov/vuln/detail/CVE-2025-5777 Follow the syntax strictly and maintain
   semantic fidelity for the workflow of identifying signs of
   exploitation".

```

The generated playbook adheres to the CACAO v2 specification, incorporating mandatory fields such as **spec\_version**, **id**, **name**, **description**, **created\_by**, **created**, **modified**, and **valid\_from**.

While the playbook is functional, several limitations may affect its execution, scalability, and reliability within a security operations environment. All commands are designated as manual, requiring an analyst to perform SIEM queries, count events, and define variables. This reliance on human intervention restricts the potential for automation, despite CACAO's support for programmatic log querying via HTTP API, ssh, or OpenC2.

Furthermore, the **target\_definitions** field remains empty, even though commands reference implicit targets such as SIEM or NetScaler logs. Explicitly defining these targets - for instance, as endpoint or network traffic - would clarify system dependencies and improve orchestration. Finally, the playbook focuses exclusively on detection and lacks integration with response workflows. Although the true branch mentions escalation, it does not automate the process or link to subsequent CACAO playbooks for containment.

The workflow illustrated in Figure 7.5 provides a graphical representation of the JSON code imported into CACAO Roaster. Although the tool's export limitations affect the image's legibility, the visualization confirms that the playbook is restricted to detection and investigation in the first prompt. Consequently, a subsequent prompt was issued to include response actions, the results of which are shown in Figure 7.6. The complete playbooks for both the initial and follow-up prompts are provided in Appendix A.3.

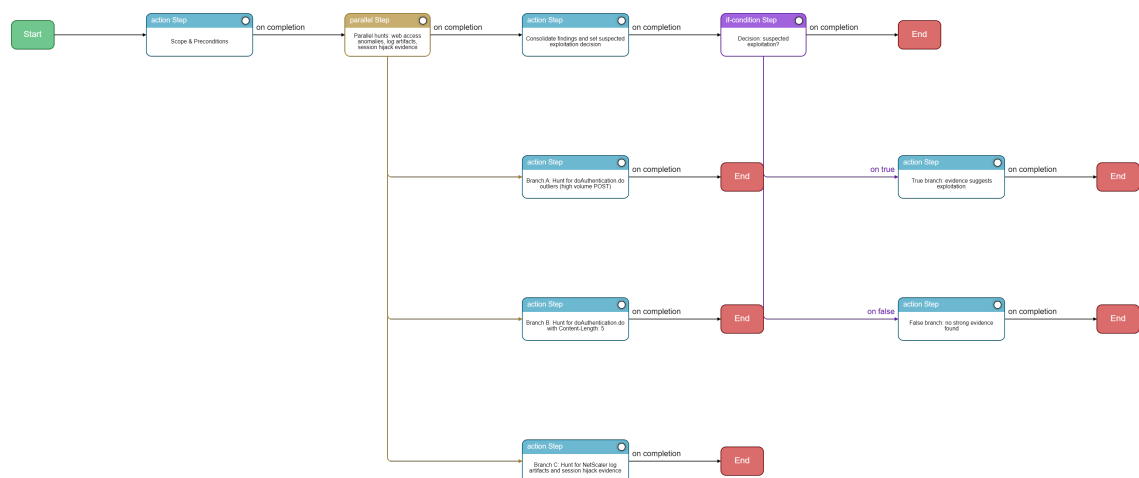


Figure 7.5: Cacao playbook with first prompt

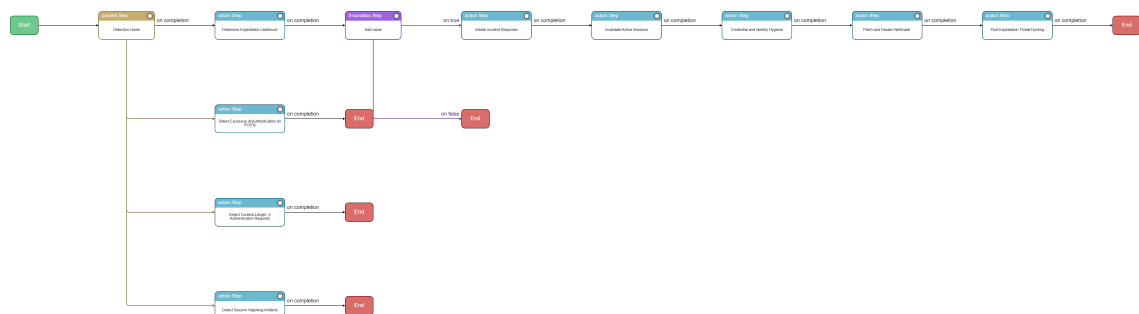


Figure 7.6: Cacao playbook with counter prompt



The playbook generated from the follow-up prompt shares the same structural flaws as the initial version; although it incorporates response actions, it completely omits `target_definitions`. As illustrated in Figure 7.6, the additional steps for responding to a detection are included, yet the command type remains set to manual.

These results align with the findings of M.A Gurabi et al. [9] regarding the necessity of precise prompt engineering. During the workshop, it was observed that other participants achieved superior results—including properly defined targets—by employing more sophisticated prompting techniques and a deeper understanding of the problem domain through iterative refinement. This suggests that with optimized prompting, AI agents could be configured to generate these playbooks with consistent accuracy and technical rigor.

## 8 Discussion and Recommendation

This chapter adopts an evaluative approach to synthesize the preceding findings. It begins by assessing the extent to which the research questions - hereafter referred to as **RQ**, followed by their respective numbers (e.g., **RQ1**) - outlined in Table 1.1 of the Introduction have been addressed. The discussion then examines specific concepts and themes that emerged during the research, offering a critical appraisal of these points. This analysis helps identify significant risks, rewards, and limitations inherent in the subject matter. Finally, the chapter concludes by proposing potential solutions and strategic recommendations based on these evaluations.

### 8.1 Discussion

Chapter 7 (Exploration and Validation) addressed RQ3 and RQ4, providing an industry perspective on the factors influencing the sharing and importation of playbooks. This exploration highlighted both positive and negative drivers of collaborative efforts in either direction (RQ3) and provided a clearer understanding of analysts' perceptions of automated playbooks within the network (RQ4).

The research suggests that developing in-house playbooks for automation does not encounter significant resistance. Since these processes remain internal, there is minimal risk of exposing sensitive organizational data. Consequently, internal playbooks primarily serve to maintain operational maturity and ensure compliance with industry standards, such as ISO/IEC 27001. This context explains why most playbooks are maintained in human-readable formats, whereas scripts are utilized specifically to automate repetitive tasks. This aligns with interview findings where the manager noted that organizations often lack extensive, formalized playbook libraries. Instead, security analysts frequently follow general response actions and implement them on an ad hoc basis. Such practices imply that operational consistency may vary significantly between different teams within the same organization.

Regarding RQ4, the findings suggest that the inquiry should have focused more specifically on orchestration rather than on automation alone. While an automated playbook may execute a single or a few tasks (a runbook), orchestration involves managing multiple tasks that require interfacing with diverse tools across the network infrastructure, as discussed in Chapter 4. Analysts expressed several reservations regarding this complexity. Ultimately, there is a general preference for orchestration, provided that the concerns identified in RQ2 and RQ6 are addressed. This relates to RQ5, which seeks to assess how well the automated playbooks scale across the infrastructure. Since the playbook was not deployed in the production environment, it is difficult to determine whether it scales; however, given CACAO's modular design, i.e., its ability to invoke external playbooks and agents, these playbooks theoretically support horizontal scalability.

It is important to reiterate that these perspectives primarily concern the internal application of playbooks and intra-organizational collaboration. When extending these efforts to external environments, security professionals must navigate the requirements for collaborative defense established by M.A Gurabi et al [18]. in Chapter 5. While these technical and procedural barriers are manageable, a more significant deterrent involves the lack of reciprocity; interviewees noted that organizations often receive no feedback or mutual

contribution after sharing resources. Although this lack of exchange discourages collaborative initiatives, it is arguably a symptom of a deeper issue. The fundamental obstacle to external collaboration is a lack of trust within the security community. If a foundation of trust were established, secondary challenges regarding reciprocity and standardization could likely be resolved over time.

However, this hesitation is not without merit. The decision not to share must have been weighed against the clear internal advantages of using playbooks. As detailed in the "Motivation for Playbooks" subsection of Chapter 7, analysts identified substantial rewards for maintaining robust internal playbooks, including reduced Mean Time to Detect (MTTD) and Mean Time to Respond (MTTR). Furthermore, playbooks ensure consistency in incident resolution and support organizational maturity and regulatory compliance. Consequently, the perceived risks to organizational security inherent in external sharing often outweigh these established internal benefits.

From the sharing party's perspective, the primary concern remains the potential disclosure of sensitive operational data. Fortunately, the CACAO specification includes a data-marking object that uses the Traffic Light Protocol (TLP) to control information dissemination, as knowledge of an organization's specific security tooling and incident response procedures can provide attackers with a blueprint for identifying vulnerabilities. However, M.A. Gurabi et al. (Chapter 5) suggest that, in addition to the TLP approach, excluding such data to preserve privacy can, in some cases, compromise the playbook's usability for the recipient. Similarly, while anonymity for playbook publishers is also proposed by M.A. Gurabi et al, simply masking an identity does not inherently foster community trust. As indicated in Table 7.2, resources from unknown publishers are often treated with the same skepticism as unverified internet sources. Establishing a mechanism to make anonymous contributions verifiable and trusted is essential, a point that will be further addressed in the recommendations.

Regarding the recipient's perspective, the research highlights significant implementation challenges. Currently, adopting a CACAO playbook requires substantial time to translate generic instructions into configurations compatible with specific organizational tools and infrastructure. If a security analyst is already familiar with the threat process, the time required to vet the playbook and translate it may yield little efficiency gain over traditional methods. However, for unfamiliar threats, these playbooks remain highly valuable, as they provide expert-defined process identification that effectively halves discovery time. To further reduce implementation overhead, the industry requires a unified vocabulary for defining processes within CACAO playbooks, supported by proprietary mapping layers that automatically translate standardized language into vendor-specific tool commands, similar to how Sigma rules are translated into vendor-specific SIEM query languages.

With respect to RQ2 and RQ6, concerning failure scenarios and the balance between human oversight and machine autonomy. It is important to prevent the misappropriation of automated steps (RQ2); playbooks should be designed to halt all actions and document their state immediately upon encountering a failure. As discussed in Chapter 4, automation and orchestration are susceptible to cascading failures if initial steps are flawed. To mitigate this risk, rate limiting should be implemented to prevent excessive iterations of automated tasks. For RQ6, the optimal balance is achieved by integrating mandatory breakpoints into the workflow. These checkpoints ensure that an analyst must approve actions, particularly those involving sensitive data or critical infrastructure, before the automation proceeds, maintaining necessary oversight within the orchestrated environment.

This leads to Research Question 1 (RQ1): Which metrics are most effective for determin-

ing whether an automated playbook complies with the ISO/IEC 27001 standard? Furthermore, if these metrics are translated from human-readable to machine-readable formats, what is the achievable level of transformation accuracy?

To ensure compliance, a CACAO playbook must first adhere to the CACAO specification, including its schema, mandatory features, workflow logic, and integrity signing. Alignment with ISO/IEC 27001 further requires that the playbook is properly documented, effective, tested, and subject to continuous improvement. For this study, we have identified several essential metrics for automated playbooks:

1. **Scenario Coverage:** The playbook should address multiple scenarios, including edge cases and failure states (e.g., rate limiting and breakpoints for human oversight).
2. **Operational Efficiency:** The playbook should help reduce the Mean Time to Detect (MTTD) and the Mean Time to Respond (MTTR).
3. **Regulatory Compliance:** Execution must align with relevant legislative frameworks.
4. **Detection Accuracy:** For detection-focused playbooks, a low false-positive trigger rate is essential.
5. **Automation Success Rate:** A high percentage of tasks must be completed successfully without manual intervention.
6. **Audit:** The playbook must automatically document all performed actions.

While legacy playbooks are becoming less critical for generation—given that chatbots can now produce CACAO playbooks using security advisories and vulnerability details—significant effort is still required to validate the resulting workflows. This ensures the playbook executes exactly as intended. Tools such as CACAO Roaster may be employed to validate syntax and structure.

Furthermore, security analysts identified graphical workflow representations as a high priority. Such visualizations assist in explaining the necessary technical steps to management and in justifying the actions required to maintain a specific security posture. Finally, observations suggest that chatbots generate CACAO playbooks with high accuracy when effective prompt engineering is employed.

## 8.2 Recommendation

To address the lack of trust, this section proposes a decentralized sharing model tailored to the Mobile Network Operator (MNO) security community. This model relies on a coordination between anonymity and a structured feedback loop, allowing participants to contribute resources while building collective confidence through peer evaluation. The approach is categorized into three primary components: decentralized sharing, anonymity, and credibility.

### 8.2.1 Decentralized Sharing

The most suitable platform for this model is the Malware Information Sharing Platform (MISP). Under this framework, Mobile Network Operators (MNOs) participating in trade associations, such as the GSMA, can synchronize their local MISP instances with those of the association as illustrated in Figure 8.1. In this scenario, the trade association creates a MISP event containing the playbook, and member organizations - such as MNO A, MNO B, and MNO C - synchronize their respective instances to receive the resource and

subsequent updates. This creates a federated network where playbooks are shared as MISP events, specifically tagged for distribution within the verified community.

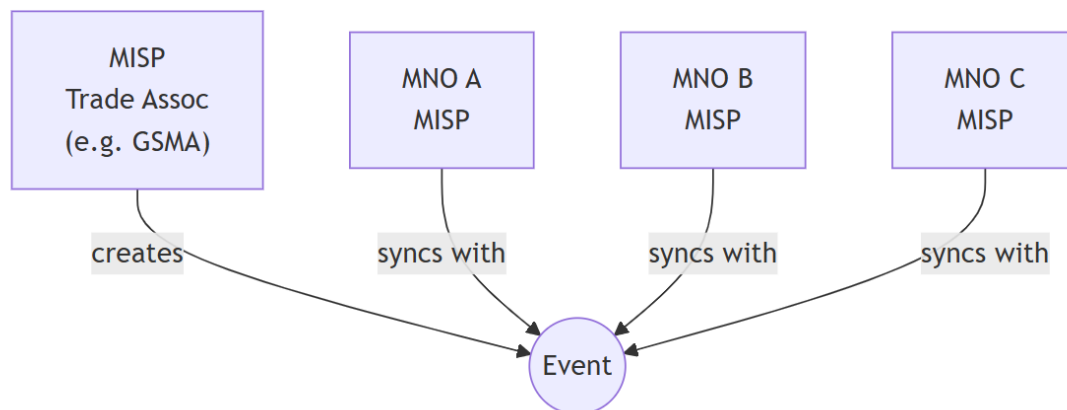


Figure 8.1: Decentralized Sharing through MISP

This approach is inherently decentralized; rather than relying on a single, central repository, each organization maintains its own instance and establishes peer-to-peer connections with others. This architecture empowers any member to publish playbooks to the collective feed while retaining local control over their data. While Figure 8.1 depicts the trade association initiating the event, the decentralized nature of the system allows any participant to serve as the source; for instance, MNO A could create an event for MNO B and MNO C to synchronize with directly. However, for such a system to be effective, it must address the publisher's identity. If an organization seeks to contribute a playbook without revealing its security posture, for the strategic reasons previously discussed, the framework must incorporate a robust mechanism for anonymity.

### 8.2.2 Anonymity

To achieve functional anonymity, this model proposes that the trade association acts as an intermediary, publishing playbooks on behalf of the contributing MNO. Depending on the association's resources and technical expertise, the vetting process can be handled in two ways: the association can perform a formal technical review, or it can rely on the established competence of the contributing MNO. This reliance on the association as a "buffer" is mitigated by the fact that the playbook remains subject to community feedback and voting to establish its ultimate credibility.

It is important to acknowledge that the effectiveness of anonymity is fundamentally tied to the size of the participant pool. In larger trade associations, the high number of members makes identifying a specific contributor nearly impossible. Conversely, in smaller groups, the probability of "guessing" the source increases, though definitive attribution remains difficult. Within the MISP framework, these communities are private and composed of trusted members, yet the playbooks themselves are shared in the standardized, open-source CACAO format to ensure interoperability.

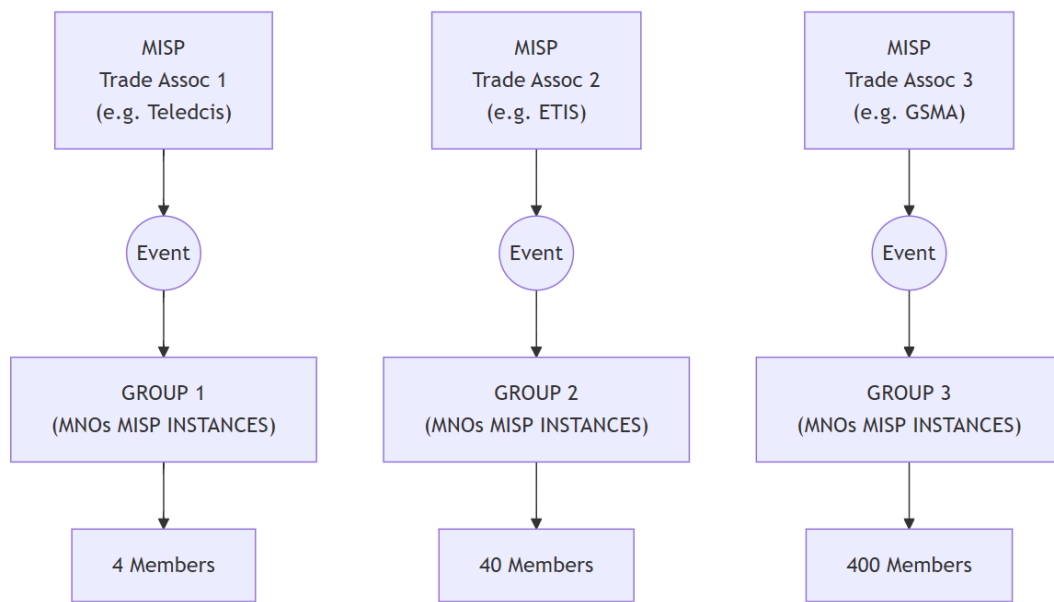


Figure 8.2: Anonymity Participant Pool

Figure 8.2 illustrates this concept by depicting three different trade associations creating MISP events. These associations represent varying scales of membership, with their respective MNOs synchronizing instances to access the playbooks. Arbitrary membership numbers are used here to demonstrate the anonymity concerns previously addressed:

1. **Trade Association 1 (Teledcis):** 4 members, representing a national level (e.g., Denmark).
2. **Trade Association 2 (ETIS):** 40 members, representing a continental level (e.g., Europe).
3. **Trade Association 3 (GSMA):** 400 members, representing a global level.

It should be noted that a member of a national association, such as Teledcis, may simultaneously participate in ETIS or GSMA, or choose to align exclusively with a single body.

From a probabilistic perspective, a member of Teledcis who contributes a playbook faces a 25% a chance of being identified. For functional anonymity to be viable, a group must consist of more than two members. In a two-member group, the non-contributing party would, by process of elimination, immediately identify the source, resulting in a 50% probability that is effectively absolute for the recipient. However, a group size exceeding two is considered sufficient for this model, as these are private forums restricted to trusted members. This assumption of baseline trust is supported by the survey data in Table 7.2, which indicates that sentimental trust among MNOs within Denmark is higher than towards those outside the national context, as noted by Group 2. By comparison, a member of the GSMA contributing a playbook—as shown in Figure 8.2—faces only a 0.25% chance of identification, representing a stark contrast in privacy protection. This variance allows participating MNOs to calibrate their involvement based on their initial level of trust. An organization may choose to begin collaboration within a smaller, high-trust trade association with fewer members and, as their confidence in the decentralized model grows,

eventually transition to sharing within larger, global forums.

### 8.2.3 Credibility

To transition from mere anonymity to established trust, the model integrates a structured feedback mechanism. Once a trade association publishes a CACAO playbook on behalf of an MNO, the responsibility for verifying its efficacy shifts to the recipient community. It is imperative that MNOs provide qualitative feedback on the playbook's utility and suggest technical refinements, such as optimized rate limiting or more robust breakpoints.

To complement these qualitative insights, a quantitative rating system (e.g., star ratings or "upvotes") should be implemented. This allows the community to identify high-value resources for specific incident types at a glance. Furthermore, a simple rating system lowers the barrier to participation for analysts who may hesitate to provide written commentary due to professional concerns, such as impostor syndrome. Through this aggregated validation, the repository becomes a self-correcting ecosystem in which the value of a playbook is determined by its proven efficacy rather than by the identity of its author.

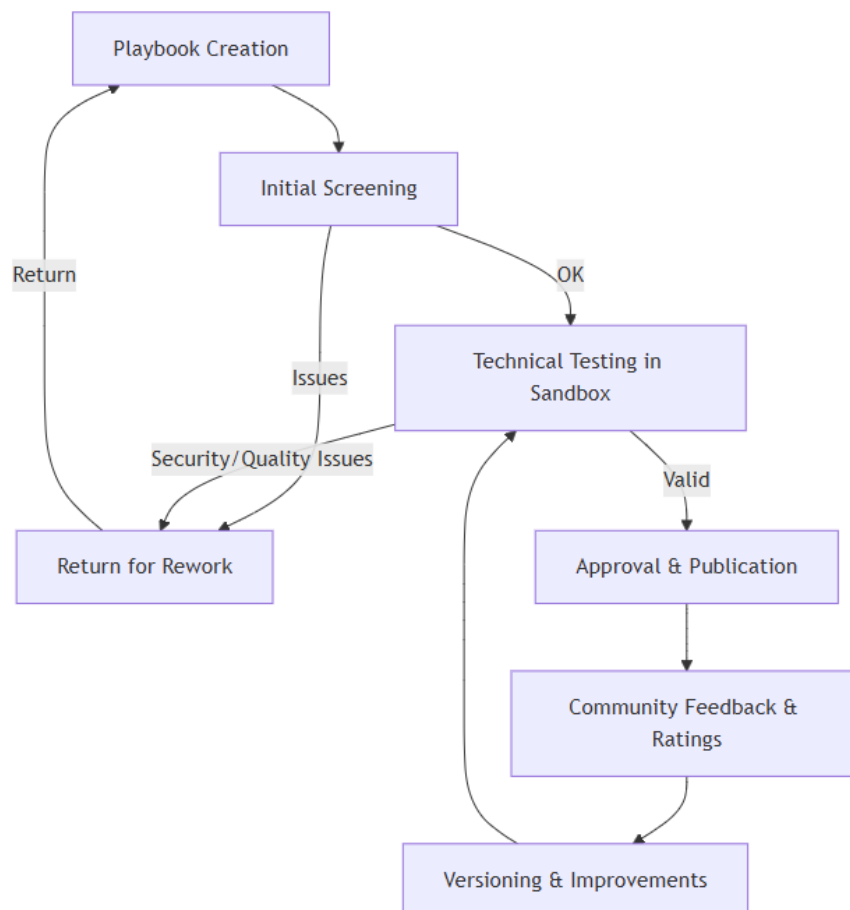


Figure 8.3: Playbook Lifecycle in the Decentralized Sharing Model

Figure 8.3 illustrates the lifecycle of a playbook designed to ensure its credibility within the community. The process begins with the originating MNO, which must validate the playbook against the CACAO schema to ensure both syntactical and semantic accuracy.

If the playbook fails this validation, it is returned for rework; otherwise, it proceeds to a testing phase within a sandbox environment. This phase simulates the playbook's execution in a production-like setting, ensuring it integrates correctly with security tools. Any identified security vulnerabilities or functional flaws at this stage trigger a return to the development phase.

Once the playbook is validated and tested, it is approved and transmitted to a trade association for publication. At this juncture, the trade association may either conduct independent screening and testing, provided it possesses the requisite technical expertise, or rely on the demonstrated competence of the contributing MNO. The association then publishes the playbook as a MISP event for the community. Upon distribution, the playbook enters a continuous improvement cycle, where it is subject to peer ratings, qualitative feedback, and versioning. While minor adjustments may be integrated directly, significant improvements are rerouted through sandbox testing to maintain the integrity and reliability of the shared resource.

The Mattermost platform is proposed as a collaborative environment for trade associations and Mobile Network Operators (MNOs) to manage cases. This space allows for the discussion and resolution of issues concerning playbooks prior to their dissemination via the MISP. By utilizing the channels, boards, and playbooks detailed in Chapter 5, stakeholders can leverage the platform's specific focus on privacy to facilitate secure coordination and by extension, lead to the sharing of strategic intelligence within the community.

#### **8.2.4 Summary**

In summary, the decentralized sharing model, illustrated in Figure 8.4, outlines the operational workflow from incident detection to community-wide distribution. The process begins when MNO A identifies an attack and develops a corresponding CACAO playbook. Depending on the specific vetting arrangements between the contributor and the trade association, the anonymity step may occur either before or after the formal vetting and validation phase.

Once the playbook is approved, it is published to a decentralized repository—specifically, a synchronized MISP instance. Other participating MNOs then retrieve these playbooks and integrate them into their local security infrastructure, such as SIEM or SOAR platforms. Following local implementation, these participants return to the MISP event to contribute feedback, provide ratings, and leave technical comments. This collaborative loop ensures the repository remains a dynamic and credible resource for the entire MNO community.



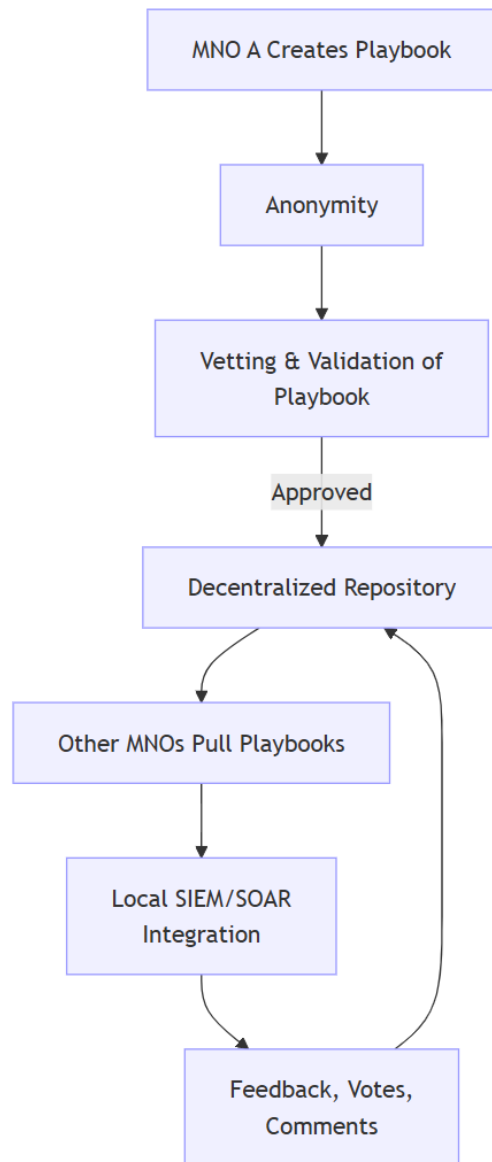


Figure 8.4: Decentralized Sharing Model

## 9 Conclusion and Future Work

This research examines the risks and benefits of collaboration among mobile network operators utilizing automated playbooks to maintain information security. While collaborative defense offers operational benefits, such as reduced Mean Time to Detection (MTTD) and Mean Time to Respond (MTTR), trust remains the primary obstacle to collective action. Once these trust-related concerns are mitigated, the development of Collaborative Automated Course of Action Operations (CACAO) playbooks by industry security professionals is expected to drive widespread adoption.

Beyond the technical application of CACAO playbooks, this study recommends a framework that empowers the security community throughout the sharing and implementation process. A decentralized sharing model that facilitates the sharing, vetting, and peer review of playbooks while preserving anonymity is better positioned to foster trust among mobile network operators. Increasing participants' ability to influence the governance of this system and its outputs will likely be directly correlated with the overall level of trust in automated playbooks.

### 9.0.1 Resolution of Research Questions

- **RQ1 & RQ5 (Standardization and Scalability):** Effective playbook implementation relies on the CACAO schema to maintain semantic accuracy, ensuring compliance with ISO/IEC 27001 metrics such as auditability and operational efficiency. This standardization enables automated playbooks to scale across diverse network infrastructures by decoupling process logic from vendor-specific tool commands.
- **RQ2 & RQ6 (Operational Oversight):** To mitigate the risk of cascading failures, playbooks must incorporate rate limiting and mandatory breakpoints, enabling high-speed automation while maintaining human oversight at critical decision points.
- **RQ3 & RQ4 (Sharing and Perception):** Although security analysts value the internal efficiency gains of automation, external collaboration is currently hindered by a lack of reciprocity and organizational trust.

As chatbots play a key role in the rapid generation of these playbooks, future research must align with this development. Predefined prompts, documents, and other resources used to configure AI agents for playbook creation can, in theory, be shared among collaborators. Furthermore, federated learning—which involves training machine learning models collaboratively without sharing sensitive raw data—offers an opportunity for collaborators to synchronize model weights by averaging local training results.

Under this framework, sharing prompts remains valuable; while the resulting playbooks may not be identical, they will remain functionally similar and subject to the proposed decentralized architecture. However, the specific risks and processes required to maintain trust in this context will require extensive research into machine learning, which remains beyond the scope of this project.

Finally, empirical validation of latency and resource consumption during multi-node execution of Cacao playbooks in a production environment to demonstrate scalability remains a subject for future research.

# References

- [1] ISO/IEC 27001:2023 *Information security management systems — Requirements*. ISO/IEC, 2023.
- [2] Mobius Software. *Mobile Network Operator (MNO)*. Mobius A2P Gateway Documentation. Mobius Software. 2024. URL: <https://www.mobius-software.com/documentation/Mobius+A2P+Gateway/Mobile+Network+Operator+%28MNO%29> (visited on 02/13/2026).
- [3] Google. *Gemini (Large Language Model) [Internet]*. Mountain View, CA, 2026. URL: <https://gemini.google.com/>.
- [4] CACAO *Security Playbooks Version 2.0*. Committee Specification 01. Latest version: <https://docs.oasis-open.org/cacao/security-playbooks/v2.0/security-playbooks-v2.0.html>. OASIS, Nov. 2023. URL: <https://docs.oasis-open.org/cacao/security-playbooks/v2.0/cs01/security-playbooks-v2.0-cs01.html>.
- [5] Daniel Schlette et al. “Do you play it by the books? A study on incident response playbooks and influencing factors”. In: *2024 IEEE Symposium on Security and Privacy (SP)*. IEEE. 2024, pp. 3625–3643.
- [6] IBM. *Information Security*. <https://www.ibm.com/think/topics/information-security>. Accessed: 27 Dec 2025. n.d.
- [7] CMMI Institute. *CMMI Levels of Capability and Performance*. <https://cmmiinstitute.com/learning/appraisals/levels>. Accessed September 2025. n.d.
- [8] IBM. *What is Business Process Modeling and Notation (BPMN)?* <https://www.ibm.com/think/topics/bpmn>. Accessed: Feb. 13, 2026. 2024.
- [9] Mehdi Akbari Gurabi et al. “From Legacy to Standard: LLM-Assisted Transformation of Cybersecurity Playbooks into CACAO Format”. In: *arXiv preprint arXiv:2508.03342* (2025).
- [10] Cheryl E Pascoe. “Public draft: The NIST cybersecurity framework 2.0”. In: *National Institute of Standards and Technology* (2023).
- [11] Fortinet. *Security Operations Center (SOC)*. <https://www.fortinet.com/resources/cyberglossary/what-is-soc>. Accessed: Jan. 6, 2026.
- [12] Arnold Johnson et al. *Guide for security-focused configuration management of information systems*. US Department of Commerce, National Institute of Standards and Technology, 2011.
- [13] Splunk. *Automation vs. Orchestration: What’s the Difference?* Accessed: May 22, 2024. 2023. URL: [https://www.splunk.com/en\\_us/blog/learn/automation-vs-orchestration.html](https://www.splunk.com/en_us/blog/learn/automation-vs-orchestration.html).
- [14] Europol. *Takedown of SMS-based FluBot spyware infecting Android phones*. <https://www.europol.europa.eu/media-press/newsroom/news/takedown-of-sms-based-flubot-spyware-infecting-android-phones>.
- [15] MISP Project. *MISP - Open Source Threat Intelligence Platform & Open Standards For Threat Information Sharing*. Accessed: Jan. 23, 2026. 2026. URL: <https://www.misp-project.org/>.
- [16] MISP Project. *MISP Playbooks*. <https://github.com/MISP/misp-playbooks/tree/main/misp-playbooks>. Accessed: Jan. 23, 2026. 2024.
- [17] Mattermost, Inc. *Mattermost: Open Source Collaboration Platform*. <https://mattermost.com/>. Accessed: Feb. 1, 2026. 2026.

- [18] Mehdi Akbari Gurabi et al. "SASP: a Semantic web-based Approach for management of Sharable cybersecurity Playbooks". In: *Proceedings of the 17th International Conference on Availability, Reliability and Security*. 2022, pp. 1–8.
- [19] CERT Société Générale. *Incident Response Methodologies: Phishing*. <https://github.com/certsocietegenerale/IRM/blob/main/EN/IRM-16-Phishing.pdf>. Accessed: Jan. 26, 2026. 2020.
- [20] OpenAI. *ChatGPT (GPT-5.2) [Internet]*. San Francisco, CA, 2026. URL: <https://chat.openai.com/>.
- [21] Sai Prashanth Puliseti and Aishwarya Singam. *Nslookup PowerShell Download Cradle*. [https://github.com/SigmaHQ/sigma/blob/master/rules/windows/powershell/powershell\\_classic/posh\\_pc\\_abuse\\_nslookup\\_with\\_dns\\_records.yml](https://github.com/SigmaHQ/sigma/blob/master/rules/windows/powershell/powershell_classic/posh_pc_abuse_nslookup_with_dns_records.yml). Sigma detection rule ID 999bff6d-dc15-44c9-9f5c-e1051bfc86e1. 2022.
- [22] National Institute of Standards and Technology (NIST). *CVE-2025-5777*. [Online]. Accessed: Jan. 7, 2026. URL: <https://nvd.nist.gov/vuln/detail/CVE-2025-5777>.



# List of Figures

|     |                                                                 |    |
|-----|-----------------------------------------------------------------|----|
| 1.1 | Asymmetry . . . . .                                             | 1  |
| 2.1 | CMMI Levels [7] . . . . .                                       | 5  |
| 2.2 | Evolution of Security Playbooks. . . . .                        | 7  |
| 2.3 | Cacao Playbook Structure [4] . . . . .                          | 10 |
| 3.1 | NIST CSF [10] . . . . .                                         | 11 |
| 3.2 | Detection Lifecycle . . . . .                                   | 12 |
| 3.3 | Incident Response Process . . . . .                             | 13 |
| 5.1 | TAXII . . . . .                                                 | 20 |
| 5.2 | Mitre Att&ck Framework . . . . .                                | 21 |
| 5.3 | Bhadra Framework . . . . .                                      | 22 |
| 5.4 | MISP [15] . . . . .                                             | 23 |
| 5.5 | Mattermost Channel[17] . . . . .                                | 24 |
| 5.6 | Mattermost Boards[17] . . . . .                                 | 25 |
| 5.7 | Mattermost Boards[17] . . . . .                                 | 25 |
| 5.8 | Mattermost Playbook[17] . . . . .                               | 26 |
| 5.9 | Mattermost Playbook . . . . .                                   | 26 |
| 7.1 | Preliminary Workflow . . . . .                                  | 30 |
| 7.2 | CACAO Roaster Interface . . . . .                               | 31 |
| 7.3 | Importing Playbook using CACAO Roaster . . . . .                | 32 |
| 7.4 | Imported Playbook . . . . .                                     | 32 |
| 7.5 | Cacao playbook with first prompt . . . . .                      | 37 |
| 7.6 | Cacao playbook with counter prompt . . . . .                    | 37 |
| 8.1 | Decentralized Sharing through MISP . . . . .                    | 42 |
| 8.2 | Anonymity Participant Pool . . . . .                            | 43 |
| 8.3 | Playbook Lifecycle in the Decentralized Sharing Model . . . . . | 44 |
| 8.4 | Decentralized Sharing Model . . . . .                           | 46 |

# List of Tables

|     |                                                              |    |
|-----|--------------------------------------------------------------|----|
| 1.1 | Research Questions . . . . .                                 | 2  |
| 3.1 | NIST CSF Functions . . . . .                                 | 11 |
| 4.1 | Modes of Automation . . . . .                                | 16 |
| 4.2 | Benefits and Risks of Automation and Orchestration . . . . . | 17 |
| 6.1 | Summary . . . . .                                            | 29 |
| 7.1 | Responses regarding automation and playbooks. . . . .        | 33 |
| 7.2 | Trust evaluation by groups . . . . .                         | 35 |

# A Appendix

## A.1 Sample Phishing CACAO Playbook

```
1  {
2  "type": "playbook",
3  "spec_version": "cacao-2.0",
4  "id": "playbook--phishing-irm16-0001",
5  "name": "Phishing Incident Response (IRM-16)",
6  "description": "Response playbook for handling phishing incidents based on
7  CERT SG IRM #16.",
8  "playbook_types": ["investigation", "mitigation", "remediation", "
9  notification"],
10 "playbook_activities": ["scan-system", "identify-indicators", "restrict-
11 access", "restore-data"],
12 "created_by": "identity--cert-sg-irm16",
13 "created": "2025-09-29T10:00:00.000Z",
14 "modified": "2025-09-29T10:00:00.000Z",
15 "workflow_start": "start--prep",
16 "workflow": {
17   "start--prep": {
18     "type": "start",
19     "name": "Start Phishing IRM",
20     "on_completion": "action--preparation"
21   },
22   "action--preparation": {
23     "type": "action",
24     "name": "Preparation",
25     "description": "Ensure awareness campaigns, contact lists, SPF/DKIM/
26     DMARC, and reporting procedures are in place.",
27     "on_completion": "action--identification",
28     "commands": [
29       {
30         "type": "manual",
31         "command": "Review readiness: awareness, contacts, monitoring,
32         reporting channels",
33         "playbook_activity": "scan-system"
34       }
35     ]
36   },
37   "action--identification": {
38     "type": "action",
39     "name": "Identification",
40     "description": "Detect phishing via spam traps, TI feeds, SIEM
41     monitoring, header/IOC analysis.",
42     "on_completion": "action--containment",
43     "commands": [
44       {
45         "type": "manual",
46         "command": "Analyze suspicious emails, domains, attachments, and
47         collect IOCs",
48         "playbook_activity": "identify-indicators"
49       }
50     ]
51   },
52   "action--containment": {
53     "type": "action",
54     "name": "Containment",
```



```

48     "description": "Block IOCs, delete phishing emails, sinkhole domains,
49         warn collaborators.",
50     "on_completion": "action--remediation",
51     "commands": [
52         {
53             "type": "manual",
54             "command": "Block malicious URLs/domains and remove phishing emails",
55             "playbook_activity": "restrict-access"
56         }
57     ],
58     "action--remediation": {
59         "type": "action",
60         "name": "Remediation",
61         "description": "Reset compromised accounts, stop ongoing campaigns,
62             contact law enforcement if targeted.",
63         "on_completion": "action--recovery",
64         "commands": [
65             {
66                 "type": "manual",
67                 "command": "Reset credentials, disable compromised accounts",
68                 "playbook_activity": "eliminate-risk"
69             }
70         ],
71     },
72     "action--recovery": {
73         "type": "action",
74         "name": "Recovery",
75         "description": "Confirm fraudulent websites/emails are taken down,
76             monitor reactivation attempts.",
77         "on_completion": "action--lessons-learned",
78         "commands": [
79             {
80                 "type": "manual",
81                 "command": "Verify takedown and restore services",
82                 "playbook_activity": "restore-capabilities"
83             }
84         ],
85     },
86     "action--lessons-learned": {
87         "type": "action",
88         "name": "Lessons Learned",
89         "description": "Document incident details, costs, IOCs, update
90             procedures and contact lists.",
91         "on_completion": "end--finish",
92         "commands": [
93             {
94                 "type": "manual",
95                 "command": "Write report, update playbooks, share with CERT/
96                     community",
97                 "playbook_activity": "compose-content"
98             }
99         ],
100     },
101     "end--finish": {
102         "type": "end",
103         "name": "End Phishing IRM Playbook"
104     }
105 },
106 "playbook_variables": {
107     "__indicator__": {

```

```
104         "type": "string",  
105         "description": "Phishing IOC under investigation"  
106     }  
107 }  
108 }
```

## A.2 CMMI Maturity Model

The CMMI model defines a staged path of five maturity levels that build upon each other, characterizing how processes evolve in organizations. The maturity levels as defined by the CMMI Institute are:

- **Level 1 (Initial):** Processes are unpredictable, reactive, and often over budget or delayed; success depends heavily on individual expertise rather than defined methods. [7].
- **Level 2 (Managed):** Introduces project-level process discipline: projects are planned, monitored, measured, and controlled to meet requirements [7].
- **Level 3 (Defined):** Common organizational standards and processes are adopted, and individual projects use these standard processes, shifting from reactive to proactive behavior [7].
- **Level 4 (Quantitatively Managed):** Moves to data-driven control, where processes are measured and controlled using statistical and quantitative techniques, making performance more predictable [7].
- **Level 5 (Optimizing):** Emphasizes continuous improvement and innovation: the organization refines and improves its processes actively, reacts flexibly to change, and institutionalizes learning [7].

## A.3 Workshop

### FIRST PROMPT

```
1      {
2      "type": "playbook",
3      "spec_version": "cacao-2.0",
4      "id": "playbook--2d2ce2e3-0b35-4c7b-99e2-6a7b9a6b4e2a",
5      "name": "Detect Signs of Exploitation: CVE-2025-5777 (CitrixBleed 2) on
6      NetScaler ADC/Gateway",
7      "description": "Hunt workflow to identify signs of exploitation/session
8      hijacking associated with CVE-2025-5777 (CitrixBleed 2). Primary signals
9      : (1) outlier volume of POST requests to doAuthentication.do, (2) POST
10     doAuthentication.do with Content-Length: 5, (3) NetScaler logs showing
11     LOGOFF with username '#' /junk values, and (4) NetScaler session/client-
12     source IP mismatches consistent with session hijacking. Analyst records
13     counts and sets a final suspected exploitation boolean used by an if-
14     condition decision.",
15     "created_by": "identity--0f7a3d8d-3fbe-4b3c-8e33-6d2f62f9d0e5",
16     "created": "2026-01-07T00:00:00Z",
17     "modified": "2026-01-07T00:00:00Z",
18     "valid_from": "2026-01-07T00:00:00Z",
19     "priority": 2,
20     "severity": 70,
21     "labels": [
22       "cve-2025-5777",
23       "citrixbleed-2",
24       "netscaler",
25       "session-hijacking",
26       "detection",
27       "investigation"
28     ],
29     "external_references": [
30       {
31         "name": "NVD CVE Record",
32         "url": "https://nvd.nist.gov/vuln/detail/CVE-2025-5777"
33       },
34       {
35         "name": "Hunting guidance (public reporting) - doAuthentication.do
36         outliers, Content-Length 5, LOGOFF user '#', IP mismatch",
37         "url": "https://doublepulsar.com/citrixbleed-2-exploitation-started-mid-
38         june-how-to-spot-it-f3106392aa71"
39       },
40       {
41         "name": "Threat discussion and observed activity (public reporting)",
42         "url": "https://reliquest.com/blog/threat-spotlight-citrix-bleed-2-
43         vulnerability-in-netscaler-adc-gateway-devices/"
44       }
45     ],
46     "playbook_types": [
47       "detection",
48       "investigation"
49     ],
50     "playbook_activities": [
51       "match-indicator",
52       "identify-indicators",
53       "analyze-collected-data",
54       "scan-system"
55     ],
56     "playbook_variables": {
57       "__time_window_start__": {
58         "type": "string",
59         "description": "RFC3339 UTC start time for the hunt window (passed in by
```

```

        calling context).",
49     "value": "",
50     "constant": false,
51     "external": true
52 },
53 "__time_window_end__": {
54     "type": "string",
55     "description": "RFC3339 UTC end time for the hunt window (passed in by
        calling context).",
56     "value": "",
57     "constant": false,
58     "external": true
59 },
60 "__netscaler_identifier__": {
61     "type": "string",
62     "description": "Identifier/name of the NetScaler ADC/Gateway instance(s)
        in scope (hostname, asset tag, or log source name).",
63     "value": "",
64     "constant": false,
65     "external": true
66 },
67 "__doauth_post_count__": {
68     "type": "integer",
69     "description": "Count of POST requests to URIs containing
        doAuthentication.do during the hunt window.",
70     "value": "0",
71     "constant": false,
72     "external": false
73 },
74 "__doauth_content_length_5_count__": {
75     "type": "integer",
76     "description": "Count of POST requests to doAuthentication.do observed
        with HTTP header Content-Length: 5 during the hunt window.",
77     "value": "0",
78     "constant": false,
79     "external": false
80 },
81 "__logoff_username_hash_count__": {
82     "type": "integer",
83     "description": "Count of NetScaler log lines indicating LOGOFF events
        where the username equals '#' (or contains junk/binary artifacts)
        during the hunt window.",
84     "value": "0",
85     "constant": false,
86     "external": false
87 },
88 "__session_ip_mismatch_count__": {
89     "type": "integer",
90     "description": "Count of NetScaler session records where source IP and
        client IP mismatch (or client IP changes within same session) during
        the hunt window.",
91     "value": "0",
92     "constant": false,
93     "external": false
94 },
95 "__suspected_exploitation__": {
96     "type": "bool",
97     "description": "Final analyst decision: set to 'true' if evidence
        suggests exploitation/session hijacking consistent with CVE
        -2025-5777 indicators; else 'false'.",
98     "value": "false",
99     "constant": false,

```

```

100     "external": false
101 },
102 "__analyst_notes__": {
103     "type": "string",
104     "description": "Free-text notes summarizing what was found (queries used
105     , top source IPs, sample log lines).",
106     "value": "",
107     "constant": false,
108     "external": false
109 },
110 "workflow_start": "start--b8c1f0a3-4d0a-4b60-9a5b-6c7e5d8c9a10",
111 "workflow": {
112     "start--b8c1f0a3-4d0a-4b60-9a5b-6c7e5d8c9a10": {
113         "type": "start",
114         "name": "Start: CVE-2025-5777 Exploitation Signs Hunt",
115         "on_completion": "action--9f2a7c6e-2a4f-4c92-9f74-9f2b13b1b7b1"
116     },
117
118     "action--9f2a7c6e-2a4f-4c92-9f74-9f2b13b1b7b1": {
119         "type": "action",
120         "name": "Scope & Preconditions",
121         "description": "Confirm the hunt window and NetScaler log sources are
122         available (AAA/auth logs, web access logs, session logs/telemetry).
123         Ensure the hunt window brackets the suspected exposure period.
124         Record any gaps in __analyst_notes__.",
125         "agent": "individual--2e7d9c41-7e83-4b6d-9e6f-12eab3af5caa",
126         "commands": [
127             {
128                 "type": "manual",
129                 "command": "Confirm __time_window_start__:value and
130                 __time_window_end__:value are set and valid RFC3339 UTC
131                 timestamps. Confirm NetScaler log sources for
132                 __netscaler_identifier__:value exist in the SIEM (web access
133                 logs and AAA/session logs). If logs are missing for the window,
134                 note gaps in __analyst_notes__:value.",
135                 "playbook_activity": "analyze-collected-data"
136             }
137         ],
138         "on_completion": "parallel--e34e2d51-7a3e-4a48-8a3f-0ef0f8c8a2b9"
139     },
140
141     "parallel--e34e2d51-7a3e-4a48-8a3f-0ef0f8c8a2b9": {
142         "type": "parallel",
143         "name": "Parallel hunts: web access anomalies, log artifacts, session
144         hijack evidence",
145         "description": "Run independent hunts in parallel. Each branch MUST end
146         in its branch end step, then execution returns here and continues
147         on_completion.",
148         "on_completion": "action--8c7d63f8-4df0-44c7-91f4-7c6d7c0e2a33",
149         "next_steps": [
150             "action--d8f1c3a2-2fb6-47c0-8d9a-7d4d89a9a4c1",
151             "action--a2d0b9ee-3f68-4e08-9b6f-2a3b0b3c9d11",
152             "action--c7c9b6d2-1b2a-4c11-9a9c-8f3e2a1b0c9a"
153         ]
154     },
155
156     "action--d8f1c3a2-2fb6-47c0-8d9a-7d4d89a9a4c1": {
157         "type": "action",
158         "name": "Branch A: Hunt for doAuthentication.do outliers (high volume
159         POST)",
160         "description": "Public reporting indicates exploitation attempts often

```

```

        generate an excessive number of requests to URIs containing
        doAuthentication.do; legitimate traffic may exist, so focus on
        outliers in volume and source IP concentration.",
"agent": "individual--2e7d9c41-7e83-4b6d-9e6f-12eab3af5caa",
"commands": [
  {
    "type": "manual",
    "command": "In SIEM web access logs for __netscaler_identifier__:
      value, within __time_window_start__:value to __time_window_end__:
      value, count requests where (method == POST) AND (uri contains
      'doAuthentication.do'). Identify top source IPs by count and
      look for outlier volumes (e.g., thousands/day from one or few
      IPs). Record the count in __doauth_post_count__:value and
      summarize top source IPs and any spikes in __analyst_notes__:
      value.",
    "playbook_activity": "match-indicator"
  },
  {
    "type": "manual",
    "command": "If available, pivot on unusual request patterns around
      doAuthentication.do (e.g., repeated bursts, tight periodicity).
      Capture at least 3 representative log lines (redacted as needed)
      in __analyst_notes__:value.",
    "playbook_activity": "analyze-collected-data"
  }
],
"on_completion": "end--a0a3f4b2-1d2e-4c3b-9a8f-0b1c2d3e4f5a"
},

"end--a0a3f4b2-1d2e-4c3b-9a8f-0b1c2d3e4f5a": {
  "type": "end",
  "name": "End Branch A"
},

"action--a2d0b9ee-3f68-4e08-9b6f-2a3b0b3c9d11": {
  "type": "action",
  "name": "Branch B: Hunt for doAuthentication.do with Content-Length: 5",
  "description": "Public reporting notes exploitation activity observed
    with POST doAuthentication.do requests including Content-Length: 5 (
    length is not immutable, but is a high-signal heuristic when
    combined with POST and endpoint).",
  "agent": "individual--2e7d9c41-7e83-4b6d-9e6f-12eab3af5caa",
  "commands": [
    {
      "type": "manual",
      "command": "In SIEM web access logs for __netscaler_identifier__:
        value, within __time_window_start__:value to __time_window_end__:
        value, find POST requests to URIs containing 'doAuthentication.
        do' where HTTP header 'Content-Length' equals '5'. Record the
        count in __doauth_content_length_5_count__:value. Record top
        source IPs and any repeated patterns in __analyst_notes__:value
        .",
      "playbook_activity": "match-indicator"
    },
    {
      "type": "manual",
      "command": "If Content-Length is not logged, use alternative logged
        fields (e.g., request_bytes, body_length) or a proxy/WAF log
        source that includes request headers. Document the alternate
        approach in __analyst_notes__:value.",
      "playbook_activity": "analyze-collected-data"
    }
  ]
}

```

```

186     ],
187     "on_completion": "end--b1b2c3d4-e5f6-47a8-9b0c-1d2e3f4a5b6c"
188 },
189
190 "end--b1b2c3d4-e5f6-47a8-9b0c-1d2e3f4a5b6c": {
191     "type": "end",
192     "name": "End Branch B"
193 },
194
195 "action--c7c9b6d2-1b2a-4c11-9a9c-8f3e2a1b0c9a": {
196     "type": "action",
197     "name": "Branch C: Hunt for NetScaler log artifacts and session hijack
198         evidence",
199     "description": "Public reporting highlights (a) LOGOFF events with
200         username '#' /junk when memory content lands in log fields (requires
201         enhanced logging), and (b) session hijacking signs such as
202         mismatched source/client IPs or client IP changes within the same
203         session.",
204     "agent": "individual--2e7d9c41-7e83-4b6d-9e6f-12eab3af5caa",
205     "commands": [
206         {
207             "type": "manual",
208             "command": "In NetScaler logs (AAA/auth/session logging) for
209                 __netscaler_identifier__:value within __time_window_start__:
210                 value to __time_window_end__:value, search for LOGOFF-related
211                 events where user == '#' (or user field contains obvious junk/
212                 binary artifacts). Record count in
213                 __logoff_username_hash_count__:value and copy a small number of
214                 representative lines (redacted) into __analyst_notes__:value.",
215             "playbook_activity": "match-indicator"
216         },
217         {
218             "type": "manual",
219             "command": "In NetScaler session telemetry/logs, hunt for sessions
220                 where 'source IP' (connection source) and 'client IP' (expected
221                 user IP) mismatch, or where client IP changes within one session
222                 , indicating potential session theft/replay. Record count in
223                 __session_ip_mismatch_count__:value and list top offending
224                 sessions/IP pairs in __analyst_notes__:value.",
225             "playbook_activity": "identify-indicators"
226         }
227     ],
228     "on_completion": "end--c0ffee00-1234-4abc-9def-001122334455"
229 },
230
231 "end--c0ffee00-1234-4abc-9def-001122334455": {
232     "type": "end",
233     "name": "End Branch C"
234 },
235
236 "action--8c7d63f8-4df0-44c7-91f4-7c6d7c0e2a33": {
237     "type": "action",
238     "name": "Consolidate findings and set suspected exploitation decision",
239     "description": "Interpret the four primary signals together. Strong
240         suspicion when multiple signals co-occur (e.g., doAuthentication
241         outliers + Content-Length: 5 and/or LOGOFF user '#' and/or session
242         IP mismatch). Set __suspected_exploitation__ accordingly and
243         document rationale in __analyst_notes__.",
244     "agent": "individual--2e7d9c41-7e83-4b6d-9e6f-12eab3af5caa",
245     "commands": [
246         {
247             "type": "manual",

```



```

228     "command": "Review counts: __doauth_post_count__:value,
        __doauth_content_length_5_count__:value,
        __logoff_username_hash_count__:value,
        __session_ip_mismatch_count__:value. If evidence suggests
        exploitation/session hijacking consistent with CVE-2025-5777
        indicators, set __suspected_exploitation__:value to 'true';
        otherwise set to 'false'. In __analyst_notes__:value, record the
        decision rationale and (if true) the highest-signal artifacts (
        top source IPs, session IDs, sample log lines).",
229     "playbook_activity": "analyze-collected-data"
230 }
231 ],
232 "on_completion": "if-condition--3a2f6d71-5a0a-4a22-a91a-1b2c3d4e5f60"
233 },
234
235 "if-condition--3a2f6d71-5a0a-4a22-a91a-1b2c3d4e5f60": {
236     "type": "if-condition",
237     "name": "Decision: suspected exploitation?",
238     "description": "Branch based on analyst-set boolean. True indicates
        signs consistent with exploitation/session hijacking; false
        indicates no strong evidence in the examined window/log sources.",
239     "condition": "__suspected_exploitation__:value == 'true'",
240     "on_true": "action--0b8d0ff1-9e2d-4a67-8e6c-7a6b5c4d3e2f",
241     "on_false": "action--1c2d3e4f-5a6b-7c8d-9e0f-112233445566",
242     "on_completion": "end--f1e2d3c4-b5a6-4798-8f70-0a1b2c3d4e5f"
243 },
244
245 "action--0b8d0ff1-9e2d-4a67-8e6c-7a6b5c4d3e2f": {
246     "type": "action",
247     "name": "True branch: evidence suggests exploitation",
248     "description": "This playbook only identifies signs of exploitation. If
        true, escalate to incident response runbooks for containment,
        credential/session invalidation, and scoping lateral movement.",
249     "agent": "individual--2e7d9c41-7e83-4b6d-9e6f-12eab3af5caa",
250     "commands": [
251     {
252         "type": "manual",
253         "command": "Flag this NetScaler as suspected compromised based on
            CVE-2025-5777 indicators. Preserve relevant logs (web access +
            AAA/session) for the hunt window and extend the window backward/
            forward if needed. Hand off __analyst_notes__:value and
            supporting artifacts to IR for containment and deeper
            investigation.",
254         "playbook_activity": "identify-indicators"
255     }
256 ],
257     "on_completion": "end--true-branch-9a8b7c6d-5e4f-3a2b-1c0d-ffeeddccbbaa"
258 },
259
260 "end--true-branch-9a8b7c6d-5e4f-3a2b-1c0d-ffeeddccbbaa": {
261     "type": "end",
262     "name": "End of true branch for suspected exploitation"
263 },
264
265 "action--1c2d3e4f-5a6b-7c8d-9e0f-112233445566": {
266     "type": "action",
267     "name": "False branch: no strong evidence found",
268     "description": "No high-confidence indicators were identified in the
        available logs for the specified window. This does not prove absence
        ; note log coverage limitations and consider expanding time window
        or enabling enhanced logging.",
269     "agent": "individual--2e7d9c41-7e83-4b6d-9e6f-12eab3af5caa",

```

```

270     "commands": [
271     {
272         "type": "manual",
273         "command": "Document that no strong CVE-2025-5777 exploitation
                signals were found for __netscaler_identifier__:value in the
                window __time_window_start__:value to __time_window_end__:value,
                based on the hunted indicators. If logging coverage was
                incomplete (e.g., headers not logged), record limitations in
                __analyst_notes__:value and consider expanding scope/time window
                .",
274         "playbook_activity": "analyze-collected-data"
275     }
276 ],
277     "on_completion": "end--false-branch-00112233-4455-6677-8899-aabbccddeeff
                "
278 },
279
280     "end--false-branch-00112233-4455-6677-8899-aabbccddeeff": {
281         "type": "end",
282         "name": "End of false branch for suspected exploitation"
283     },
284
285     "end--f1e2d3c4-b5a6-4798-8f70-0a1b2c3d4e5f": {
286         "type": "end",
287         "name": "End: CVE-2025-5777 exploitation signs hunt completed"
288     }
289 },
290     "agent_definitions": {
291         "individual--2e7d9c41-7e83-4b6d-9e6f-12eab3af5caa": {
292             "type": "individual",
293             "name": "SOC Analyst",
294             "description": "Human analyst executing SIEM queries and recording
                results into CACAO variables."
295         }
296     },
297     "target_definitions": {}
298 }

```

## COUNTER PROMPT RESULT

```

1      {
2      "type": "playbook",
3      "spec_version": "cacao-2.0",
4      "id": "playbook--a1d9c5d2-6c4e-4c9c-bab3-9c7c3e0e5777",
5      "name": "Detect and Respond to Exploitation Signs: CVE-2025-5777 (
        CitrixBleed 2)",
6      "description": "CACAO v2.0 playbook to identify and respond to signs of
        exploitation related to CVE-2025-5777 (CitrixBleed 2) affecting Citrix
        NetScaler ADC/Gateway devices. Detection focuses on anomalous
        authentication traffic, memory-leak artifacts in logs, and session
        hijacking indicators. Response actions address session invalidation,
        credential hygiene, containment, and post-exploitation scoping.",
7      "created": "2026-01-07T00:00:00Z",
8      "modified": "2026-01-07T00:00:00Z",
9      "priority": 1,
10     "severity": 80,
11     "playbook_types": [
12         "detection",
13         "investigation",
14         "response"

```

```

15 ],
16 "labels": [
17     "cve-2025-5777",
18     "citrixbleed-2",
19     "netscaler",
20     "session-hijacking",
21     "incident-response"
22 ],
23
24 "playbook_variables": {
25     "__time_window_start__": {
26         "type": "string",
27         "description": "Start of analysis window (RFC3339 UTC).",
28         "value": "",
29         "external": true
30     },
31     "__time_window_end__": {
32         "type": "string",
33         "description": "End of analysis window (RFC3339 UTC).",
34         "value": "",
35         "external": true
36     },
37     "__netscaler_identifier__": {
38         "type": "string",
39         "description": "Hostname or asset identifier of NetScaler device(s).",
40         "value": "",
41         "external": true
42     },
43     "__doauth_post_count__": {
44         "type": "integer",
45         "value": "0"
46     },
47     "__doauth_content_length_5_count__": {
48         "type": "integer",
49         "value": "0"
50     },
51     "__logoff_username_hash_count__": {
52         "type": "integer",
53         "value": "0"
54     },
55     "__session_ip_mismatch_count__": {
56         "type": "integer",
57         "value": "0"
58     },
59     "__suspected_exploitation__": {
60         "type": "bool",
61         "value": "false"
62     },
63     "__analyst_notes__": {
64         "type": "string",
65         "value": ""
66     }
67 },
68
69 "workflow_start": "start--detect",
70
71 "workflow": {
72
73     "start--detect": {
74         "type": "start",
75         "name": "Start Detection",
76         "on_completion": "parallel--detect-hunts"

```

```

77     },
78
79     "parallel--detect-hunts": {
80         "type": "parallel",
81         "name": "Detection Hunts",
82         "description": "Parallel detection of exploitation indicators.",
83         "next_steps": [
84             "action--hunt-doauth-volume",
85             "action--hunt-content-length",
86             "action--hunt-session-artifacts"
87         ],
88         "on_completion": "action--consolidate-findings"
89     },
90
91     "action--hunt-doauth-volume": {
92         "type": "action",
93         "name": "Detect Excessive doAuthentication.do POSTs",
94         "commands": [
95             {
96                 "type": "manual",
97                 "command": "Query NetScaler web access logs between
98                             __time_window_start__:value and __time_window_end__:value for
99                             POST requests where URI contains 'doAuthentication.do'. Identify
100                             abnormal request volumes or single-source IP concentration.
101                             Record total count in __doauth_post_count__:value and document
102                             findings in __analyst_notes__:value.",
103                 "playbook_activity": "match-indicator"
104             }
105         ],
106         "on_completion": "end--branch-a"
107     },
108
109     "end--branch-a": {
110         "type": "end"
111     },
112
113     "action--hunt-content-length": {
114         "type": "action",
115         "name": "Detect Content-Length: 5 Authentication Requests",
116         "commands": [
117             {
118                 "type": "manual",
119                 "command": "Search for POST requests to doAuthentication.do with
120                             HTTP header Content-Length equal to 5. Record occurrences in
121                             __doauth_content_length_5_count__:value and log source IPs in
122                             __analyst_notes__:value.",
123                 "playbook_activity": "match-indicator"
124             }
125         ],
126         "on_completion": "end--branch-b"
127     },
128
129     "end--branch-b": {
130         "type": "end"
131     },
132
133     "action--hunt-session-artifacts": {
134         "type": "action",
135         "name": "Detect Session Hijacking Artifacts",
136         "commands": [
137             {
138                 "type": "manual",

```

```

131         "command": "Review NetScaler AAA/session logs for LOGOFF events
132             where username is '#' or non-printable. Record count in
133             __logoff_username_hash_count__:value.",
134         "playbook_activity": "match-indicator"
135     },
136     {
137         "type": "manual",
138         "command": "Identify sessions where source IP differs from client IP
139             or where client IP changes mid-session. Record count in
140             __session_ip_mismatch_count__:value.",
141         "playbook_activity": "identify-indicators"
142     }
143 ],
144 "on_completion": "end--branch-c"
145 },
146 "end--branch-c": {
147     "type": "end"
148 },
149 "action--consolidate-findings": {
150     "type": "action",
151     "name": "Determine Exploitation Likelihood",
152     "commands": [
153         {
154             "type": "manual",
155             "command": "Evaluate combined indicators. If multiple high-
156                 confidence signals are present (e.g., doAuthentication outliers
157                 plus session IP mismatch), set __suspected_exploitation__:value
158                 to 'true'. Document justification in __analyst_notes__:value.",
159             "playbook_activity": "analyze-collected-data"
160         }
161     ],
162     "on_completion": "if-condition--exploit-decision"
163 },
164 "if-condition--exploit-decision": {
165     "type": "if-condition",
166     "condition": "__suspected_exploitation__:value == 'true'",
167     "on_true": "action--response-initiation",
168     "on_false": "end--no-exploitation"
169 },
170 "end--no-exploitation": {
171     "type": "end",
172     "name": "No Exploitation Detected"
173 },
174 "action--response-initiation": {
175     "type": "action",
176     "name": "Initiate Incident Response",
177     "description": "Begin containment and remediation actions for confirmed
178         or suspected exploitation.",
179     "commands": [
180         {
181             "type": "manual",
182             "command": "Declare a security incident for CVE-2025-5777 affecting
183                 __netscaler_identifier__:value. Preserve all relevant logs and
184                 restrict administrative access to the appliance.",
185             "playbook_activity": "identify-indicators"
186         }
187     ],

```

```

183     "on_completion": "action--invalidate-sessions"
184 },
185
186 "action--invalidate-sessions": {
187     "type": "action",
188     "name": "Invalidate Active Sessions",
189     "commands": [
190         {
191             "type": "manual",
192             "command": "Force logout of all active NetScaler ICA/VPN/web
sessions. Invalidate session cookies and tokens to disrupt
potential hijacked sessions.",
193             "playbook_activity": "containment"
194         }
195     ],
196     "on_completion": "action--credential-hygiene"
197 },
198
199 "action--credential-hygiene": {
200     "type": "action",
201     "name": "Credential and Identity Hygiene",
202     "commands": [
203         {
204             "type": "manual",
205             "command": "Reset credentials for users with active sessions during
the exploitation window. Prioritize privileged, VPN, and SSO-
linked accounts. Enforce MFA re-registration if applicable.",
206             "playbook_activity": "containment"
207         }
208     ],
209     "on_completion": "action--patch-and-harden"
210 },
211
212 "action--patch-and-harden": {
213     "type": "action",
214     "name": "Patch and Harden NetScaler",
215     "commands": [
216         {
217             "type": "manual",
218             "command": "Apply Citrix security updates addressing CVE-2025-5777.
Reboot appliance as required. Enable enhanced logging for AAA
and session activity post-remediation.",
219             "playbook_activity": "mitigation"
220         }
221     ],
222     "on_completion": "action--post-exploitation-hunt"
223 },
224
225 "action--post-exploitation-hunt": {
226     "type": "action",
227     "name": "Post-Exploitation Threat Hunting",
228     "commands": [
229         {
230             "type": "manual",
231             "command": "Hunt enterprise logs for lateral movement, anomalous VPN
access, or authentication from IPs associated with suspected
hijacked sessions. Scope beyond the NetScaler device.",
232             "playbook_activity": "analyze-collected-data"
233         }
234     ],
235     "on_completion": "end--incident-response-complete"
236 },

```

```
237
238     "end--incident-response-complete": {
239         "type": "end",
240         "name": "Incident Response Completed"
241     }
242 }
243 }
```

## A.4 Academic Polishing Agent

You are an academic editor. Your task is to polish the provided text into a clear, formal academic tone without altering the author's original ideas, intent, or argumentative structure.

### **Core requirements:**

Preserve semantic fidelity: do not add, remove, or reinterpret claims.

Maintain the author's voice and perspective while improving clarity and rigor.

Improve grammar, syntax, cohesion, and precision. Avoid sophisticated words to maintain readability and understanding.

Replace informal phrasing with discipline-appropriate academic language.

Avoid generic or formulaic phrasing commonly associated with AI-generated text.

Do not introduce citations, references, or new content unless explicitly provided.

Do not paraphrase so aggressively that the text becomes unrecognizable or risks misrepresenting the author's meaning.

### **Style constraints:**

Write in natural, human-like academic prose.

Vary sentence structure and rhythm appropriately.

Avoid clichés, stock transitions, and overly polished or robotic phrasing.

Favor clarity and concision over verbosity.

### **Integrity safeguards:**

Ensure the output is original and non-plagiaristic.

Do not mimic the style of any specific author or source.

If a sentence is already clear and appropriate, leave it largely unchanged.

### **Output:**

Return only the revised text, with no commentary, explanations, or meta-language.



## A.5 Abbreviations

**AAA:** Authentication, Authorization, and Accounting.

**ADC:** Application Delivery Controller.

**AI:** Artificial Intelligence.

**API:** Application Programming Interface.

**BPMN:** Business Process Model and Notation.

**CACAO:** Collaborative Automated Course of Action Operations.

**CIA:** Confidentiality, Integrity, and Availability.

**CISO:** Chief Information Security Officer.

**CMMI:** Capability Maturity Model Integration.

**CSF:** Cybersecurity Framework.

**CSIRT:** Computer Security Incident Response Team.

**CTI:** Cyber Threat Intelligence.

**CVE:** Common Vulnerabilities and Exposures.

**DGA:** Domain Generation Algorithm.

**DK:** Denmark.

**EDR:** Endpoint Detection and Response.

**GDPR:** General Data Protection Regulation.

**GSMA:** Global System for Mobile Communications Association.

**GUI:** Graphical User Interface.

**HTTP:** Hypertext Transfer Protocol.

**HTTPS:** Hypertext Transfer Protocol Secure.

**IDS:** Intrusion Detection System.

**IoC:** Indicator of Compromise.

**IP:** Internet Protocol.

**IRM:** Incident Response Methodology.

**ISMS:** Information Security Management System.

**ISO/IEC:** International Organization for Standardization / International Electrotechnical Commission.

**IT:** Information Technology.

**JSON:** JavaScript Object Notation.

**LLM:** Large Language Model.

**MISP:** Malware Information Sharing Platform.

**MNO:** Mobile Network Operator.

**MFA:** Multi-Factor Authentication.

**MTTD:** Mean Time to Detect.

**MTTR:** Mean Time to Respond.

**MTTx:** Mean Time to [Detection/Response].

**NDR:** Network Detection and Response.

**NIST:** National Institute of Standards and Technology.

**OASIS:** Organization for the Advancement of Structured Information Standards.

**OT:** Operational Technology.

**PDCA:** Plan-Do-Check-Act.

**PDF:** Portable Document Format.

**RAG:** Retrieval-Augmented Generation.

**RQ:** Research Question.

**SIEM:** Security Information and Event Management.

**SIM:** Subscriber Identity Module.

**SMS:** Short Message Service.

**SOAR:** Security Orchestration, Automation, and Response.

**SOARCA:** Security Orchestrator for CACAO.

**SOC:** Security Operations Centre.

**SPOC:** Single Point of Contact.

**SSH:** Secure Shell.

**SS7:** Signaling System No. 7.

**STIX:** Structured Threat Information Expression.

**TAXII:** Trusted Automated Exchange of Intelligence Information.

**TLP:** Traffic Light Protocol.

**TTP:** Tactics, Techniques, and Procedures.

**UE:** User Equipment.

**URL:** Uniform Resource Locator.

**VPN:** Virtual Private Network.

**WAF:** Web Application Firewall.

**YAML:** Yet Another Markup Language.

Technical  
University of  
Denmark

Ørstedes Plads, Building 343  
2800 Kgs. Lyngby  
Tlf. 4525 1700

[www.electro.dtu.dk](http://www.electro.dtu.dk)